



FICBANK

FICBANK

Penetration Testing Plan & Report

VERSION 2

JUNE 22 2026

PUBLIC PORTFOLIO VERSION - Educational cybersecurity lab project. All testing was performed in an authorized UMGC laboratory environment. Test credentials and sensitive evidence have been redacted.

Table of Contents

1.	Executive Summary.....	4
2.	Rules of Engagement.....	4
2.1.	Introduction.....	4
2.1.1.	Penetration Testing.....	4
2.1.2.	Vulnerability Testing.....	5
2.1.3.	Post-Testing Actions.....	5
3.	Penetration Testing Methodologies.....	6
3.1.	Phase 1: Reconnaissance and Enumeration.....	6
3.1.1.	Publicly Available Information.....	6
3.1.2.	Service Banner and Fingerprinting Information.....	6
3.1.3.	Live Hosts.....	6
3.1.4.	Traceroute.....	7
3.1.5.	Nmap.....	7
3.2.	Phase 2: Vulnerability Discovery.....	7
3.2.1.	Live Hosts.....	7
3.2.2.	Open Ports and Services.....	8
3.2.3.	Nikto, Dirb, and WPSan.....	8
3.2.4.	OpenVAS.....	8
3.3.	Phase 3: Exploitation.....	8
3.3.1.	Findings.....	9
3.4.	Phase 4: Recommendations.....	9
4.	Appendices of Evidence.....	10
4.1.	Appendix A – Reconnaissance and Enumeration Phase.....	10
4.2.	Appendix B – Vulnerability Discovery Phase.....	10
4.3.	Appendix C – Exploitation Phase.....	10
4.4.	Appendix D – Post-Exploitation Cleanup Phase.....	10

Penetration Testing Plan & Report (PTR)

Prepared By

	Organization that Prepared this Document	
	Organization Name	University of Maryland Global Campus Penetration Testing Team
	Street Address	3501 University Blvd East
	Suite/Room/Building	
	City, State, Zip	Adelphi, MD 20783

Prepared For

	Organization that Prepared this Document	
	Organization Name	FICBANK
	Street Address	2386 Highway 76
	Suite/Room/Building	
	City, State, Zip	Denver, Colorado 80201

Document Revision History

Version	Date	Pages	Description	Author
1.0	<date of initiation>	All	Draft creation	UMGC
2	6/22/2026	ALL	Project 1: Reconnaissance	LOIC NDEH
3	7/5/2026	all	Project 2: Discovery	Loic Ndeh
4	7/18/2026	all	Project 3: Exploitation of Vulnerabilities	Loic Ndeh
5	7/27/2026	ALL	Project 4: Post-Exploitation	Loic ndeh

1. Executive Summary

FICBANK engaged the University of Maryland Global Campus Penetration Testing Team (UMGC PTT) to perform an authorized penetration test of its information technology infrastructure to evaluate the effectiveness of existing security controls and identify

vulnerabilities that could be exploited by malicious actors. The assessment was conducted using industry-standard penetration testing methodologies consistent with National Institute of Standards and Technology (NIST) Special Publication 800-115 and included reconnaissance, vulnerability discovery, exploitation, post-exploitation analysis, and reporting.

During the engagement, the assessment identified multiple security findings affecting the organization's attack surface, including publicly accessible network services, missing HTTP security headers, exposed web directories, weak cryptographic configurations, and vulnerabilities that could be leveraged through social engineering attacks. Controlled exploitation activities demonstrated that attackers could potentially obtain unauthorized access or capture user credentials if these weaknesses remain unaddressed. All exploitation activities were conducted exclusively within the authorized laboratory environment and in accordance with the approved Rules of Engagement.

Overall, the assessment found that FICBANK has implemented several effective security controls, including firewall filtering, network segmentation, and restricted access to selected services. However, additional improvements are recommended to strengthen the organization's overall security posture, reduce the attack surface, improve user awareness, and mitigate identified vulnerabilities before they can be exploited in a production environment. Implementation of the recommendations contained in this report will improve system resilience, reduce organizational risk, and enhance FICBANK's ability to detect, prevent, and respond to future cyber threats

2. Rules of Engagement

During the penetration test, the University of Maryland Global Campus Penetration Testing Team (UMGC PTT) conducted an authorized assessment of FICBANK's information technology infrastructure to identify vulnerabilities that could adversely affect the confidentiality, integrity, and availability of organizational systems and data. The assessment evaluated network devices, web applications, publicly accessible services, and existing security controls using a combination of automated scanning tools and controlled manual testing techniques. All testing activities were performed within the approved scope and in accordance with industry best practices and applicable federal guidance.

The engagement included reconnaissance, vulnerability discovery, exploitation of selected vulnerabilities, post-exploitation analysis, documentation of findings, and development of remediation recommendations. Testing activities were carefully controlled to minimize operational impact while validating the effectiveness of existing security controls. No destructive testing was performed, and all activities were conducted within the authorized laboratory environment.

Penetration Testing Objectives

The primary objectives of this penetration test were to:

- Identify vulnerabilities, security weaknesses, and misconfigurations within the FICBANK network and supporting infrastructure.
- Evaluate the effectiveness of existing security controls, including firewall protections, authentication mechanisms, and network segmentation.
- Validate whether identified vulnerabilities could be successfully exploited by an attacker using commonly available penetration testing tools and techniques.
- Assess the organization's ability to protect sensitive information and detect unauthorized access attempts.
- Provide practical remediation recommendations to reduce organizational risk, strengthen the overall security posture, and improve future security operations.

2.1. Introduction

Under the Federal Information Security Management Act of 2002 (FISMA), the Office of Management and Budget (OMB) directed the National Institute of Standards and Technology (NIST) to develop specific guidance for federal agencies and those providing services on behalf of federal agencies to test and assess the security of their information systems. Network vulnerability assessments and penetration testing are conducted in accordance with **NIST Special Publication 800-115, Technical Guide to Information Security Testing and Assessment**, which establishes best practices for planning, executing, and documenting security assessments.

This Rules of Engagement establishes the guidelines for the University of Maryland Global Campus Penetration Testing Team (UMGC PTT) to conduct vulnerability assessments and penetration testing of **FICBANK's** enterprise systems and network infrastructure. Within this document, the terms *test* and *testing* refer to authorized vulnerability assessments and penetration testing activities performed to evaluate the confidentiality, integrity, and availability of the **FICBANK Enterprise Network**.

This document also serves as formal authorization for the UMGC PTT to conduct approved security testing activities against FICBANK assets within the defined scope of the engagement. The results of these activities are intended to identify security weaknesses, validate existing security controls, and provide recommendations that will improve the organization's overall cybersecurity posture.

2.1.1. Penetration Testing

Penetration testing is a controlled security assessment that simulates real-world cyberattacks to evaluate the effectiveness of an organization's security controls. Unlike automated vulnerability scans that only identify potential weaknesses, penetration testing validates whether those weaknesses can be successfully exploited by an attacker and assesses the potential impact on organizational operations.

During this engagement, the University of Maryland Global Campus Penetration Testing Team (UMGC PTT) performed authorized penetration testing against the FICBANK Enterprise Network using both automated and manual testing techniques. Activities included reconnaissance, network enumeration, vulnerability discovery, controlled exploitation using the Metasploit

Framework and the Social Engineering Toolkit (SET), post-exploitation analysis, and documentation of remediation recommendations. All testing activities were conducted within the approved scope and authorized laboratory environment.

The penetration test was performed to accomplish the following objectives:

- Evaluate the overall security posture of the FICBANK Enterprise Network.
- Validate whether identified vulnerabilities could be successfully exploited.
- Assess the effectiveness of existing security controls, including firewall protections, authentication mechanisms, and network segmentation.
- Identify weaknesses that could increase the risk of unauthorized access, privilege escalation, or credential compromise.
- Provide prioritized remediation recommendations that reduce organizational risk and improve the overall security posture.

The results of this assessment provide FICBANK management with a comprehensive understanding of the organization's current security posture and actionable recommendations to strengthen defenses against future cyber threats.

2.1.2. Vulnerability Testing

Vulnerability testing is a systematic process used to identify security weaknesses, configuration errors, outdated software, and other conditions that could be exploited by threat actors. Unlike penetration testing, which attempts to actively exploit vulnerabilities, vulnerability testing focuses on discovering and evaluating security issues before they can be abused. The information obtained during vulnerability testing provides the foundation for prioritizing remediation efforts and improving the organization's overall security posture.

During this assessment, the University of Maryland Global Campus Penetration Testing Team (UMGC PTT) conducted vulnerability testing of the FICBANK Enterprise Network using industry-standard security tools, including Nmap, Nikto, DIRB, WPScan, and OpenVAS. These tools were used to identify active hosts, enumerate open ports and services, discover web application weaknesses, assess cryptographic configurations, and identify known vulnerabilities affecting the target systems.

The vulnerability assessment identified several security findings, including missing HTTP security headers, exposed web directories, weak SSL/TLS cipher suites, weak SSH message authentication code (MAC) algorithms, and an outdated scan environment. Although some findings represented configuration weaknesses rather than immediately exploitable vulnerabilities, each increases organizational risk and should be addressed through timely remediation and continuous security monitoring.

The results of the vulnerability assessment were used to prioritize risks based on their potential business impact and likelihood of exploitation. These findings also guided the controlled

exploitation activities performed during the subsequent penetration testing phase and provided the basis for the remediation recommendations presented later in this report.

2.1.3. Post-Testing Actions

Upon completion of the penetration testing activities, the University of Maryland Global Campus Penetration Testing Team (UMGC PTT) performed post-testing activities to ensure the testing environment was properly documented and that no unnecessary artifacts remained from the assessment. Post-testing actions are an essential component of a professional penetration test because they help restore systems to their original state, reduce operational risk, and provide the client with clear guidance for remediation.

During this engagement, exploitation activities were conducted within the authorized laboratory environment using controlled testing techniques. Following completion of the assessment, all testing sessions were terminated, temporary exploitation artifacts were removed where applicable, and no unauthorized persistence mechanisms or privileged accounts were left on the target systems. Any credentials captured during the simulated phishing exercise were used solely for validation purposes within the lab environment and were not retained beyond the assessment.

The findings from all phases of the engagement were reviewed, validated, and documented in this report. Each identified vulnerability was assigned appropriate remediation recommendations designed to reduce organizational risk and improve the overall security posture of the FICBANK Enterprise Network. Management should prioritize remediation activities according to the severity of each finding and implement continuous vulnerability management practices to ensure that future weaknesses are identified and addressed promptly.

Consistent with **NIST SP 800-53 Revision 5, SI-2 (Flaw Remediation)**, FICBANK should establish procedures to track identified vulnerabilities, verify corrective actions, perform follow-up validation testing, and maintain documentation demonstrating that remediation activities have been successfully completed. Regular penetration testing and vulnerability assessments should also be incorporated into the organization's ongoing cybersecurity program to support continuous improvement and reduce the likelihood of future compromise.

3. Penetration Testing Methodologies

3.1. Phase 1: Reconnaissance and Enumeration

3.1.1. Publicly Available Information

i) Finding 1 – Multiple Active Hosts Identified

A ping sweep of the 10.13.246.0/24 subnet identified nine active hosts responding to network probes. The presence of multiple active systems increases the organization's attack surface and provides potential targets for further reconnaissance and vulnerability assessment activities.

Recommendation: Maintain an accurate asset inventory and continuously monitor active hosts to identify unauthorized or unmanaged devices.

ii) Finding 2 – Publicly Accessible DNS and Domain Information

DIG, NSLOOKUP, and WHOIS reconnaissance revealed publicly accessible DNS records, IP addresses, domain registration details, and authoritative name servers associated with the target domain. This information can be leveraged by attackers to map infrastructure and conduct targeted attacks.

Recommendation: Regularly review public DNS records and domain registration information to ensure unnecessary information is not exposed.

iii) Finding 3 – Exposed Network Services

Nmap service enumeration identified several exposed services, including HTTP (80), HTTPS (443), SSH (22), and Freeciv (5555). Publicly accessible services represent potential attack vectors if vulnerabilities or misconfigurations exist.

Recommendation: Restrict unnecessary services, implement secure configurations, enforce strong authentication controls, and perform regular vulnerability assessments.

iv) Finding 4 – Firewall Filtering and Network Security Controls Detected

The targeted Nmap scan against 10.13.246.8 showed that ports 21 (FTP), 23 (Telnet), and 53 (DNS) were filtered. Additionally, traceroute responses were blocked, preventing route discovery. These results indicate the presence of firewall protections and network filtering controls.

Recommendation: Continue maintaining firewall rules, review access-control policies regularly, and implement network segmentation to further reduce exposure.

3.1.2. Service Banner and Fingerprinting Information

Service Banner and Fingerprinting Results	
Dig	DNS query for umgc-web-dvwa.azurewebsites.net successfully resolved to IP address 10.13.246.8. Query completed successfully with status NOERROR.
Dig	DNS query for umgc.edu returned four A records: 151.101.195.10, 151.101.67.10, 151.101.131.10, and

	151.101.3.10. Query completed successfully with status NOERROR.
<i>Nslookup</i>	Resolved umgc.edu to IP addresses 151.101.67.10, 151.101.195.10, 151.101.3.10, and 151.101.131.10.
<i>whois</i>	Identified domain registration information for umgc.edu, including technical contact information, authoritative name servers, domain activation date (27-Jun-2019), last updated date (10-May-2025), and expiration date (31-Jul-2027).

3.1.3. Live Hosts

Ping Sweep Results	
Host 1	10.13.246.5 – Host is up (0.0022s latency)
Host 2	10.13.246.8 – Host is up (0.0019s latency)
Host 3	10.13.246.9 – Host is up (0.0019s latency)

3.1.4. Traceroute

Traceroute Results	
Host (10.13.246.8)	Traceroute attempted from Kali Linux to 10.13.246.8. The trace displayed 10 hops, with each hop returning " * * ". No intermediate routers responded to the traceroute probes. This indicates that ICMP responses were filtered, blocked, or not configured to respond. The destination path could not be fully mapped.
Hop 1	* * * (No response)
Hop 2	* * * (No response)

3.1.5. Nmap

Nmap Enumeration Results	
10.13.246.14	80/tcp(http)open , 443/tcp(http)open
10.13.246.15	22/tcp(ssh)open , 80/tcp(http)open, 5555/tcp freeciv
10.13.246.18	80/tcp(http)open , 443/tcp(http)open

3.2. Phase 2: Vulnerability Discovery

3.2.1. Live Hosts

Report

Objective

A host discovery scan was performed using Nmap to identify all active systems within the DVWA network (10.13.246.0/24). Establishing a network baseline before conducting further discovery activities helps ensure that subsequent port and service scans target only responsive hosts.

Command Used

```
nmap -sn 10.13.246.0/24
```

Results

The Nmap ping sweep identified **9 active hosts** on the target subnet. Each responding host replied successfully to host discovery probes, confirming that the systems were online and reachable during testing.

Analysis

The host discovery scan successfully established the current network baseline by identifying nine responsive devices on the DVWA subnet. Comparing these findings with previous reconnaissance activities showed that the network landscape remained consistent, indicating no unexpected hosts had appeared or disappeared. Identifying active systems before performing port and service enumeration improves scanning efficiency while reducing unnecessary traffic directed toward inactive addresses.

Nmap Scan for Live Hosts Results	
10.13.246.5	UP
10.13.246.8	UP
10.13.246.9	UP

3.2.2. Open Ports and Services

Nmap Scan for Open Ports and Services Results	
10.13.246.5	TCP 80 (HTTP), TCP 443 (HTTPS)
10.13.246.8	TCP 80 (HTTP), TCP 443 (HTTPS)
10.13.246.9	TCP 80 (HTTP), TCP 443 (HTTPS)

3.2.3. Nikto, Dirb, and WPScan

4. Instructions:

Nikto, Dirb, and WPScan Results	
DIRB (http://umgc-web-dvwa.azurewebsites.net)	Discovered accessible directories (/config/, /docs/, /external/), favicon.ico, php.ini, phpinfo.php, robots.txt, and server-status (403 Forbidden).
Nikto (http://10.13.246.8)	Missing security headers (X-Frame-Options, X-XSS-Protection, X-Content-Type-Options), no CGI directories found, no server banner, 3 informational findings.
WPScan (http://10.13.246.8)	Scan aborted because the target is not running WordPress . No WordPress vulnerabilities identified.

3.2.4. OpenVAS

OpeVAS Results		
Target	Severity Level	Vulnerability Name
10.15.41.196	High (10.0)	Report Outdated / End-of-Life Scan Engine / Environment (Local)
10.15.41.196	Medium (5.9)	SSL/TLS: Report Weak Cipher Suites
10.15.41.196	Low (2.6)	Weak MAC Algorithm(s) Supported (SSH)

Summary

The OpenVAS vulnerability assessment identified three findings affecting the target host. The scan reported one **High**, one **Medium**, and one **Low** severity vulnerability related to the scan environment and cryptographic configurations. Detailed analysis, remediation recommendations, and supporting evidence are provided in **Appendix B (Figure B-7)**.

3.3. Phase 3: Exploitation

Note: We are combining two phases- vulnerability analysis and exploitation- in this phase. We can do this because of the compressed nature of the course and the hands-on exercise environment. In the wild, you would typically analyze discovered vulnerabilities as a distinct phase. Such analysis might consist of prioritization, technical deep dive, custom exploit development to match the vulnerability, and so forth.

3.3.1. Findings

Task	Documented Findings
-Payloads and Exploits	<i>Metasploit Framework (MSF) was used to identify and exploit a known vulnerability. The msfvenom -h command was executed to review payload generation options available within Metasploit. Next, the search vsftpd command located the exploit/unix/ftp/vsftpd_234_backdoor module, which targets the VSFTPD v2.3.4 backdoor vulnerability. The exploit module was identified with an Excellent reliability ranking, indicating it is a highly dependable exploit for systems running the vulnerable FTP service. This confirmed that Metasploit provides built-in exploit modules capable of leveraging known software vulnerabilities to gain unauthorized access during penetration testing.</i>

-Social Engineering Toolkit	The Social Engineering Toolkit (SET) was launched to simulate a social engineering attack. The Web Attack module was selected, followed by the Credential Harvester method. The Google login page was chosen as the phishing template, allowing SET to clone the legitimate website and host a local phishing page that closely resembled the original. The toolkit automatically configured the web server and displayed instructions regarding optional redirect settings after successful credential submission. This demonstrated how attackers can replicate trusted websites to deceive users into submitting sensitive information.
-Phishing Attack Using Credential Harvester	A simulated phishing attack was successfully executed using SET's Credential Harvester. When test credentials were entered into the cloned Google login page, SET captured the submitted information, including the email address ([REDACTED TEST EMAIL]) and password ([REDACTED TEST PASSWORD]), and displayed them in the terminal. This confirmed that the Credential Harvester can intercept user-supplied credentials during a phishing attack. This activity was performed only within the authorized UMGC laboratory environment for educational purposes.

3.4. Phase 4: Post-Exploitation Recommendations

No.	Your Findings	Remediation Recommendations
1	Missing HTTP Security Headers The Nikto vulnerability assessment identified that the target web server was missing several recommended HTTP security headers, including X-Frame-Options , X-XSS-Protection , and X-Content-Type-Options . Although these missing headers do not directly compromise the server, they reduce browser-based protections and increase the likelihood of attacks such as clickjacking, cross-site scripting (XSS), and MIME-type confusion. Attackers may exploit these weaknesses to trick users into interacting with malicious web content or executing unauthorized script	Configure the web server to implement all recommended HTTP security headers in accordance with current industry best practices. Specifically, enable X-Frame-Options to prevent clickjacking attacks, X-Content-Type-Options to prevent MIME-type sniffing, and implement modern protections such as a Content Security Policy (CSP) to reduce the risk of cross-site scripting attacks. Web server configurations should be reviewed regularly following software updates to ensure required security headers remain enabled. Periodic vulnerability assessments should also be performed to verify that secure configurations are consistently maintained across all public-facing web applications.
2	Exposed Web Directories and Sensitive Files	Restrict public access to administrative, configuration, documentation, and development directories unless they are required for business operations. Remove

	The DIRB scan identified several publicly accessible directories and files, including /config/, /docs/, /external/, php.ini, phpinfo.php, robots.txt, and favicon.ico. Although some resources did not immediately expose sensitive information, publicly accessible configuration files, documentation, and application directories provide valuable reconnaissance information that attackers can use to better understand the application's structure and identify additional attack vectors.	unnecessary files such as phpinfo.php from production systems because they may disclose software versions, server configurations, and installed modules that attackers can leverage during reconnaissance. Implement the principle of least privilege by ensuring only authorized users can access sensitive resources through proper authentication and authorization controls. Regular web application assessments should also be performed to identify newly exposed files and directories before they can be exploited by threat actors.
3	Weak SSL/TLS Cipher Suites The OpenVAS vulnerability assessment identified that the target system supports weak SSL/TLS cipher suites. Weak cryptographic algorithms can reduce the effectiveness of encrypted communications and increase the risk of attackers intercepting or decrypting sensitive information through cryptographic attacks. Although exploitation may require significant resources, the continued use of weak cipher suites does not align with current cybersecurity best practices and increases organizational risk	Update the server's Transport Layer Security (TLS) configuration to disable weak and deprecated cipher suites and permit only strong, industry-approved cryptographic algorithms. Configure systems to support TLS 1.2 and TLS 1.3 while disabling outdated protocols and insecure cipher suites. Regularly review cryptographic configurations against current security standards, apply vendor security updates promptly, and perform periodic vulnerability assessments to verify that encryption settings remain compliant with organizational security policies and industry best practices.
4	Weak SSH Message Authentication Code (MAC) Algorithms The OpenVAS assessment identified that the Secure Shell (SSH) service supports weak Message Authentication Code (MAC) algorithms. Although SSH traffic is encrypted, weak MAC algorithms reduce the integrity protection of SSH communications and may increase the risk of cryptographic attacks against remote administrative sessions. Attackers who successfully intercept network traffic could potentially exploit weaker cryptographic algorithms under certain conditions, reducing the overall security of remote management connections.	Configure the SSH service to disable weak and deprecated MAC algorithms and enable only strong, modern cryptographic algorithms that comply with current security best practices. System administrators should regularly update OpenSSH software, review SSH configuration files after system upgrades, and restrict remote administrative access to authorized personnel through the use of multifactor authentication, network segmentation, and access control lists. Routine security assessments should be conducted to verify that secure cryptographic configurations remain in place and that legacy algorithms are not re-enabled during future system updates.
5	Outdated Software and End-of-Life Components	Implement a comprehensive patch and vulnerability management program to ensure all operating systems, applications, and supporting software are maintained

	The OpenVAS vulnerability assessment identified an outdated or end-of-life software component within the assessed environment. Systems running unsupported or outdated software no longer receive security patches from the vendor, increasing the likelihood that known vulnerabilities can be exploited by attackers. Failure to maintain current software versions significantly increases organizational risk because publicly available exploits frequently target unsupported applications and operating systems.	with current vendor-supported versions. End-of-life software should be upgraded or replaced as soon as practical to eliminate exposure to known vulnerabilities. Organizations should establish a formal patch management process that includes regular vulnerability scanning, testing of security updates before deployment, prioritization of critical vulnerabilities, and verification that remediation activities have been successfully completed. Maintaining an accurate inventory of hardware and software assets will also help ensure unsupported systems are identified and addressed before they become security risks.
6	Vulnerable FTP Service (VSFTPD 2.3.4 Backdoor) During the exploitation phase, the Metasploit Framework identified the VSFTPD 2.3.4 backdoor exploit module as applicable to the vulnerable FTP service. This vulnerability is associated with a malicious backdoor that can provide attackers with unauthorized remote access to a system if the compromised version of the software is in use. The successful identification of this exploit demonstrates how attackers can leverage publicly available exploit frameworks to compromise outdated or vulnerable services if they remain exposed to the network	Immediately identify and replace any vulnerable or unsupported versions of FTP services with vendor-supported software that has all current security patches applied. If FTP services are not required for business operations, they should be disabled or removed to reduce the organization's attack surface. Where file transfer services are necessary, secure alternatives such as SFTP (SSH File Transfer Protocol) or FTPS (FTP Secure) should be implemented to provide encrypted communications and stronger authentication. Additionally, organizations should perform routine vulnerability scanning and configuration reviews to identify outdated services before they can be exploited by threat actors.
7	Susceptibility to Social Engineering Attacks During the penetration test, the Social Engineering Toolkit (SET) was successfully used to clone a legitimate Google login page and host a simulated phishing website. The exercise demonstrated how attackers can create convincing replicas of trusted websites to deceive users into entering sensitive information. This finding highlights that technical security controls alone cannot fully protect an organization if users are susceptible to social engineering techniques.	Implement a comprehensive security awareness and phishing training program for all employees to reduce the likelihood of successful social engineering attacks. Training should educate users on recognizing phishing emails, verifying website authenticity, identifying suspicious links and attachments, and reporting suspected phishing attempts to the appropriate security personnel. In addition, FICBANK should conduct periodic simulated phishing campaigns to measure employee awareness, reinforce secure behaviors, and identify departments or individuals who may benefit from additional training. Strengthening user awareness should be complemented by technical controls such as email filtering, Domain-based Message Authentication, Reporting, and Conformance (DMARC), Sender Policy Framework (SPF), DomainKeys Identified Mail (DKIM), and multifactor authentication to provide multiple layers of defense against phishing attacks.

8	Credential Harvesting Through Phishing The simulated phishing exercise successfully captured user credentials entered into the cloned Google login page using the Social Engineering Toolkit (SET). This demonstrated that user credentials could be compromised if employees unknowingly submit sensitive information to fraudulent websites. Successful credential theft significantly increases the risk of unauthorized access, privilege escalation, data breaches, and lateral movement within the organization's network if additional security controls are not in place.	Implement strong identity and access management (IAM) controls to reduce the impact of compromised credentials. Multifactor authentication (MFA) should be required for all user accounts, particularly privileged and remote-access accounts, to prevent attackers from gaining access using stolen passwords alone. FICBANK should also implement password policies requiring strong, unique passwords, monitor authentication logs for suspicious login activity, enable account lockout protections against repeated failed login attempts, and deploy identity monitoring solutions capable of detecting abnormal authentication behavior. Regular password security training and periodic credential audits should be conducted to reduce the likelihood of credential compromise and strengthen the organization's overall identity security posture.
9	Finding Exposed Network Services and Attack Surface Reconnaissance and vulnerability discovery activities identified several publicly accessible network services, including HTTP (80), HTTPS (443), SSH (22), and FTP-related services. While some services are required to support business operations, each exposed service increases the organization's attack surface and provides potential entry points that attackers can target during reconnaissance and exploitation. Improperly configured or unnecessary services may expose vulnerabilities, misconfigurations, or outdated software that can be leveraged to gain unauthorized access.	Implement an attack surface management program to continuously identify, monitor, and reduce unnecessary externally accessible services. Disable or remove services that are no longer required for business operations, restrict administrative services such as SSH through firewall rules and network segmentation, and enforce the principle of least privilege for all remote access. Periodic network discovery scans should be conducted to verify that only approved services are exposed and that newly deployed systems comply with organizational security standards. In addition, change management procedures should require security reviews before new services are made publicly accessible to ensure they do not introduce unnecessary risk.
10	Need for Continuous Vulnerability Management and Penetration Testing The penetration testing engagement identified multiple vulnerabilities and security weaknesses across the reconnaissance, vulnerability discovery, and exploitation phases. While several findings can be remediated through technical configuration changes, cybersecurity threats continue to evolve, and new vulnerabilities are discovered regularly. Relying solely on periodic	Establish a continuous vulnerability management and penetration testing program as part of FICBANK's overall cybersecurity governance strategy. Regular vulnerability assessments should be performed to identify newly discovered weaknesses, while comprehensive penetration tests should be conducted at least annually and after significant infrastructure or application changes. The organization should also implement continuous security monitoring, maintain an enterprise asset inventory, prioritize remediation efforts using a risk-based approach, and routinely verify that corrective actions have been successfully implemented. Integrating these activities into the organization's cybersecurity lifecycle will improve resilience against emerging threats, strengthen regulatory compliance, and support ongoing protection of critical business systems and sensitive information.



	security reviews increases the risk that newly introduced weaknesses will remain undetected until they are exploited by malicious actors.	
--	---	--

4. Appendices of Evidence

4.1. Appendix A – Reconnaissance and Enumeration Phase

A.1 DIG Results

Objective

Perform DNS reconnaissance and fingerprinting to identify IP address information associated with target domains.

Command Executed

DIG Query for DVWA Host

```
dig umgc-web-dvwa.azurewebsites.net
```

DIG Query for UMGc Domain

```
dig umgc.edu
```

Results

Query 1 – umgc-web-dvwa.azurewebsites.net

Field	Result
Domain Name	umgc-web-dvwa.azurewebsites.net
Record Type	A
IP Address	10.13.246.8
Query Status	NOERROR
Query Time	8 ms
DNS Server	10.205.1.15

Query 2 – umgc.edu

Field	Result
Domain Name	umgc.edu
Record Type	A
IP Addresses	151.101.195.10
	151.101.67.10
	151.101.131.10

Field	Result
	151.101.3.10
Query Status	NOERROR
Query Time	16 ms
DNS Server	10.205.1.15

Analysis

The DIG utility successfully resolved both domain names to their associated IPv4 addresses. The domain umgc-web-dvwa.azurewebsites.net resolved to the internal lab address 10.13.246.8, confirming the target host identified during earlier reconnaissance activities.

The query for **umgc.edu** returned four separate A records, indicating the use of multiple servers or load balancing to provide high availability and improved performance. Multiple DNS records are commonly used by organizations to distribute traffic across several systems.

The successful responses and NOERROR status indicate that the DNS infrastructure is functioning correctly and providing valid name resolution services.

Conclusion

DNS fingerprinting successfully identified the IP address associated with the DVWA target system and revealed multiple public-facing IP addresses associated with the UMGc domain. This information can be used to support additional reconnaissance and network enumeration activities.

Screenshot References

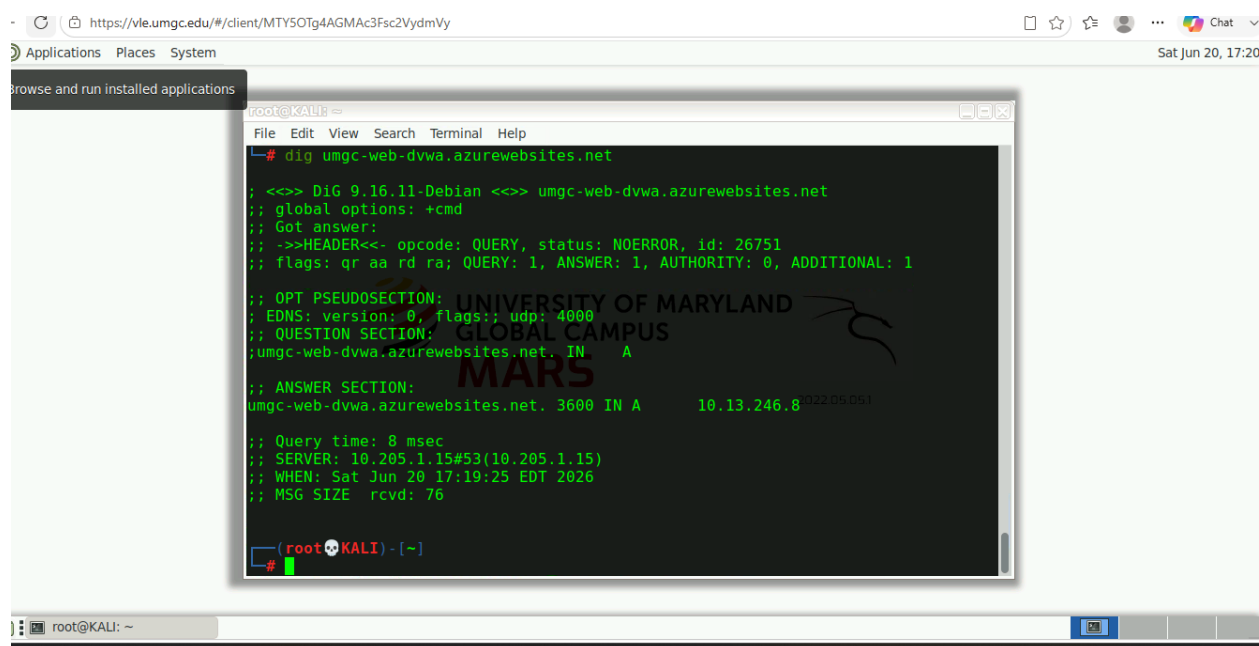


Figure A-1. DIG Query Results for umgc-web-dvwa.azurewebsites.net

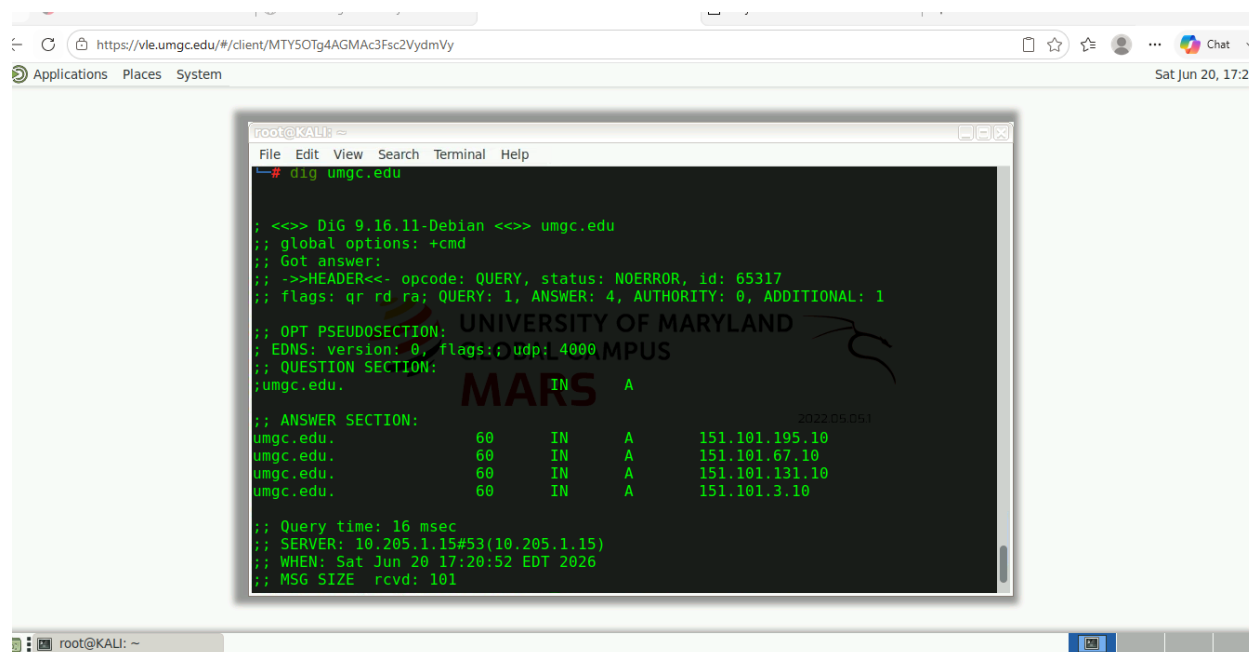


Figure A-1. DIG Query Results for umgc-web-dvwa.azurewebsites.net

Appendix B – NSLOOKUP and WHOIS Results

Objective

Perform DNS and domain registration reconnaissance to identify IP address information, domain ownership details, and DNS infrastructure associated with the target domain.

Command Executed

A.2 NSLOOKUP Results

Objective

Perform DNS reconnaissance to identify IP address information associated with the target domain and verify DNS name resolution.

Command Executed

nslookup umgc.edu

Results

Field	Value
Domain	umgc.edu
DNS Server	10.205.1.15
IP Address 1	151.101.67.10

Field Value

IP Address 2 151.101.195.10

IP Address 3 151.101.3.10

IP Address 4 151.101.131.10

Analysis

The NSLOOKUP utility successfully resolved the domain **umgc.edu** to four public IP addresses. The presence of multiple IP addresses suggests that the organization uses load balancing and redundant infrastructure to improve availability and reliability. DNS resolution was successful through the DNS server at 10.205.1.15, confirming that the domain is properly configured and reachable.

The results were consistent with the information gathered during the DIG reconnaissance activity, validating the accuracy of the DNS records identified during the enumeration process.

Conclusion

NSLOOKUP successfully identified multiple IP addresses associated with the UMGc domain and verified proper DNS functionality. The results provide valuable information regarding the organization's external-facing infrastructure and support further reconnaissance and enumeration activities.

Screenshot Reference

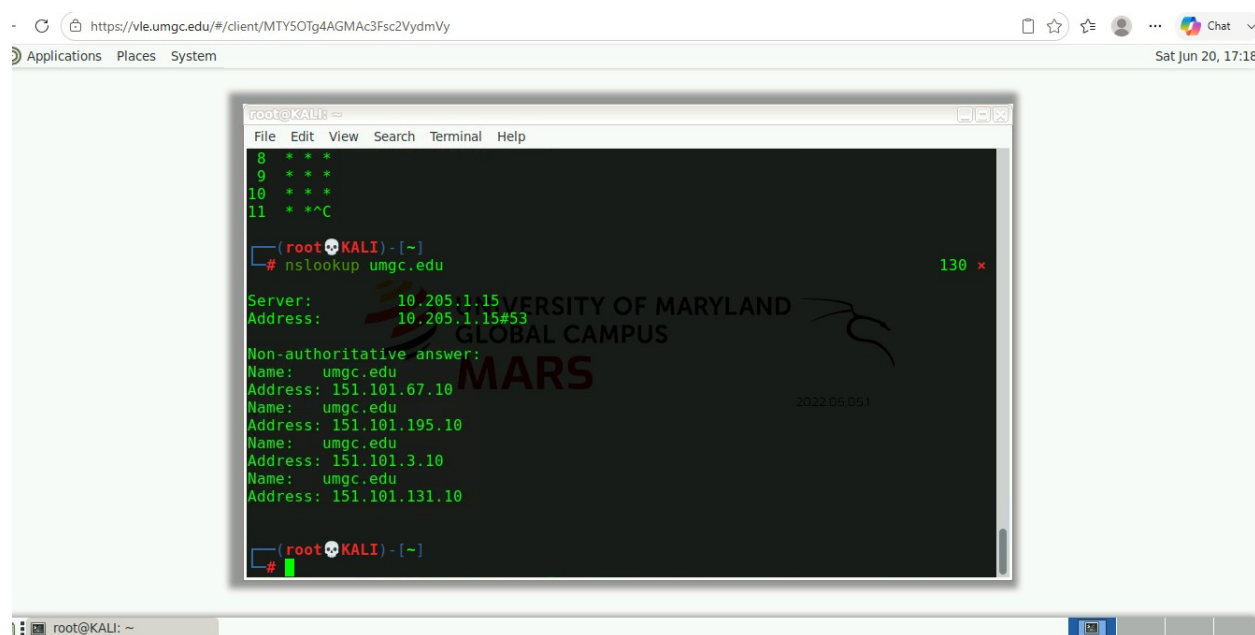


Figure A-3. NSLOOKUP Results for umgc.edu Showing DNS Resolution and Multiple IP Addresses

A.3 WHOIS Results

Objective

Perform domain registration reconnaissance to identify ownership information, administrative contacts, registration dates, and DNS infrastructure associated with the target domain.

Command Executed

```
whois umgc.edu
```

Results

Field	Value
Organization	University of Maryland University College
Technical Contact	DNS Administrator
Address	3501 University Blvd East, Adelphi, MD 20783
Phone	+1.3019857447
Email	dns-admin@umuc.edu
Domain Activated	27-Jun-2019
Last Updated	10-May-2025
Domain Expires	31-Jul-2027

Name Servers

- NS-1246.AWSDNS-27.ORG
- NS-758.AWSDNS-30.NET
- NS-412.AWSDNS-51.COM
- NS-1863.AWSDNS-40.CO.UK

Analysis

The WHOIS query provided valuable domain registration and administrative information for the UMGC domain. The results identified the organization responsible for the domain, technical contact information, registration dates, and authoritative name servers.

The presence of Amazon AWS name servers indicates that the organization utilizes Amazon Web Services DNS infrastructure to support domain name resolution. The registration information shows that the domain is actively maintained and remains valid through July 2027.

From a reconnaissance perspective, WHOIS information can help security professionals understand domain ownership, identify infrastructure providers, and verify the legitimacy of internet-facing assets.

FICBANK Penetration Testing Plan & Report for FICBANK Enterprise Network Version 5.0, July 27, 2026

However, publicly available registration data can also provide useful intelligence to attackers conducting reconnaissance.

Conclusion

WHOIS reconnaissance successfully identified domain ownership information, administrative contacts, registration dates, and authoritative DNS servers associated with the UMGc domain. This information contributes to a better understanding of the target environment and supports subsequent security assessment activities.

Screenshot Reference

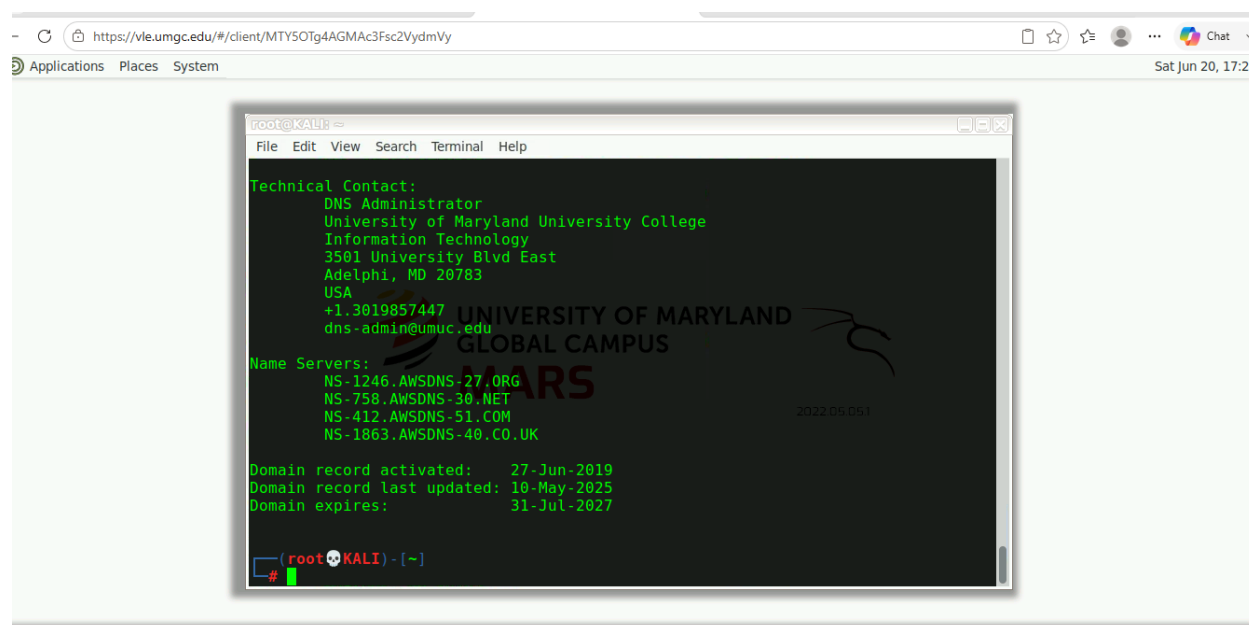


Figure A-4. WHOIS Results for umgc.edu Showing Domain Registration and Name Server Information

A.4 Ping Sweep Results

Objective

Identify active hosts on the target network and verify network connectivity using ICMP echo requests.

Command Executed

Host Discovery Scan

```
nmap -sP 10.13.246.*
```

Connectivity Verification

```
ping -b 10.13.246.15
```

Results

Active Hosts Discovered

Host	IP Address	Status	Latency
Host 1	10.13.246.5	Up	0.0022s
Host 2	10.13.246.8	Up	0.0019s
Host 3	10.13.246.9	Up	0.0019s
Host 4	10.13.246.10	Up	0.0024s
Host 5	10.13.246.11	Up	0.0015s
Host 6	10.13.246.12	Up	0.0023s
Host 7	10.13.246.14	Up	0.0021s
Host 8	10.13.246.15	Up	0.0021s
Host 9	10.13.246.18	Up	0.0018s

Ping Verification Results

Target Host	Packets Sent	Packets Received	Packet Loss
10.13.246.15	6	6	0%

Ping Statistics

Metric	Value
Minimum RTT	1.190 ms
Average RTT	1.418 ms
Maximum RTT	2.073 ms
Mean Deviation	0.297 ms

Analysis

The ping sweep successfully identified nine active hosts within the 10.13.246.0/24 subnet. All discovered systems responded to ICMP probes, confirming that they were online and reachable at the time of the assessment.

To validate the host discovery results, a direct ping test was performed against host 10.13.246.15. The host responded to all six ICMP echo requests with zero packet loss and an average round-trip time of 1.418 milliseconds, demonstrating reliable network connectivity and low latency.

FICBANK Penetration Testing Plan & Report for FICBANK Enterprise Network Version 5.0, July 27, 2026

The results indicate that the network is operational and that the discovered hosts can be targeted for further reconnaissance activities such as traceroute analysis, service enumeration, and vulnerability assessment.

Conclusion

The ping sweep identified nine active hosts on the target network. Subsequent verification testing confirmed successful communication with host 10.13.246.15, indicating stable network connectivity and validating the host discovery results.

Screenshot References

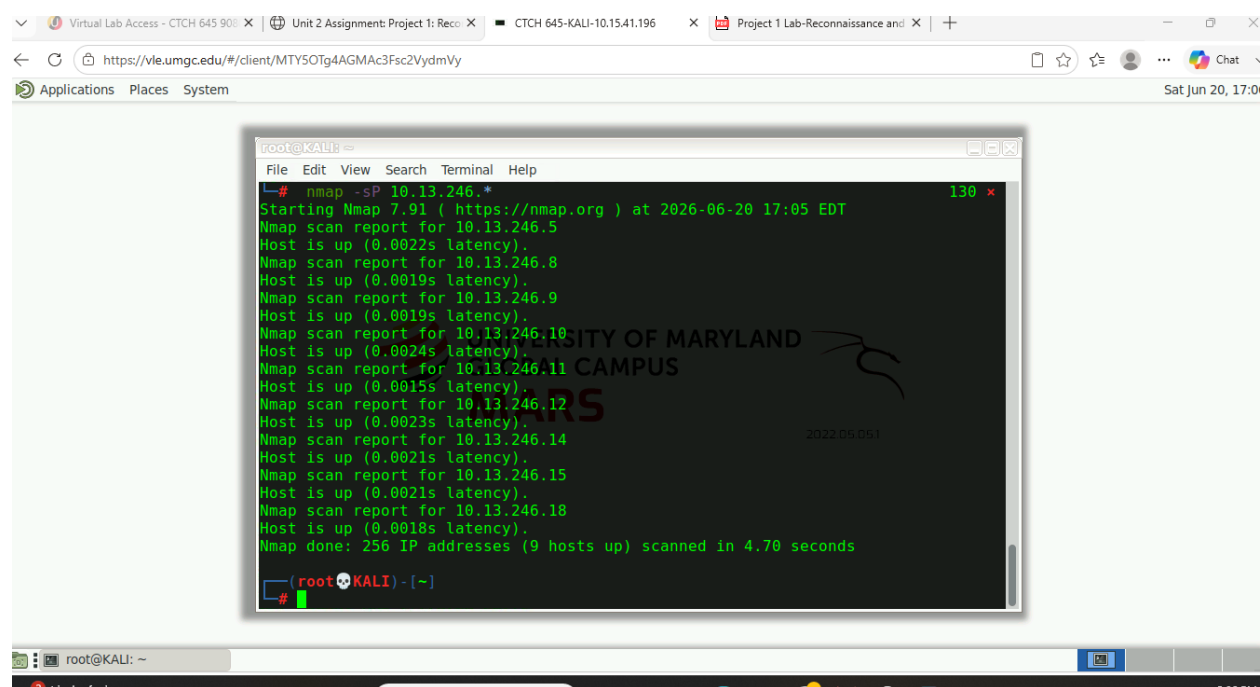


Figure A-5. Nmap Ping Sweep Results Showing Nine Active Hosts on the 10.13.246.0/24 Network

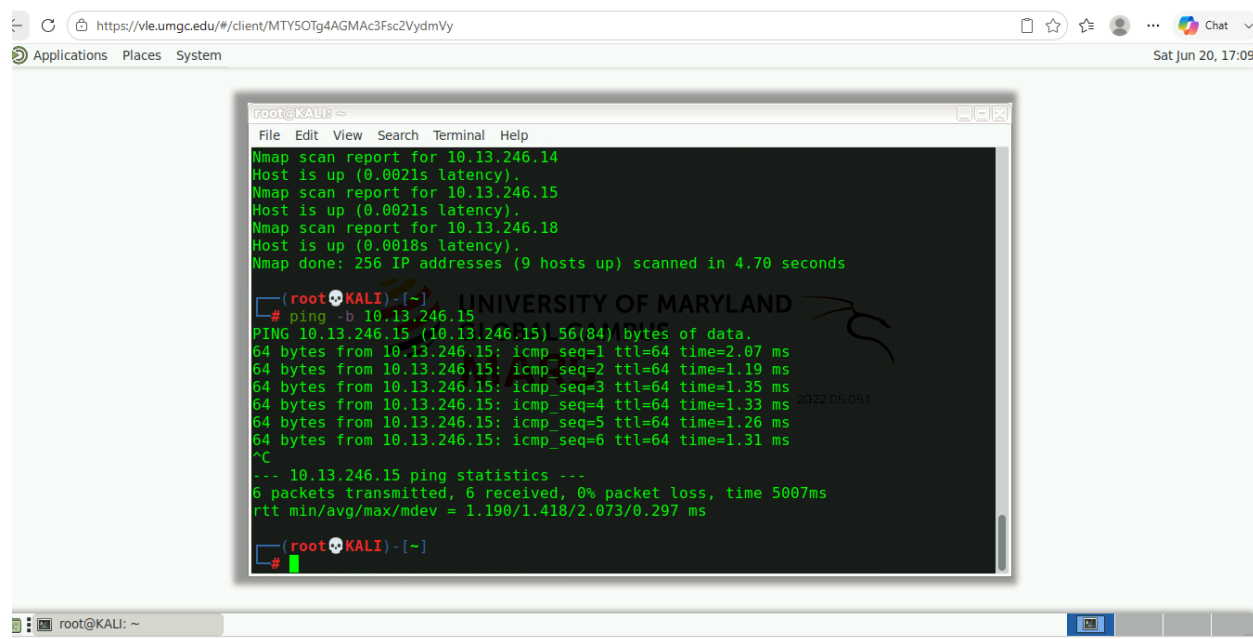


Figure A-6. ICMP Ping Verification of Host 10.13.246.15 Showing Successful Connectivity and Zero Packet Loss

A.5 Traceroute Results

Objective

Perform a traceroute from the Kali Linux system to Host 2 (10.13.246.8) to identify the network path between the source and destination.

Command Executed

traceroute 10.13.246.8

Results Observed

- Destination IP Address: **10.13.246.8**
- Maximum hops allowed: **30**
- Packet size: **60 bytes**
- Hops displayed: **10**
- Every hop returned " * "
- No router or gateway information was revealed.
- The traceroute was manually stopped using **Ctrl+C** after hop 10.

Analysis

The traceroute was unsuccessful in identifying the route to the destination host because all intermediate devices failed to respond. This behavior commonly occurs when:

1. ICMP traffic is blocked by a firewall.
2. Routers are configured not to send ICMP Time Exceeded messages.
3. Network security policies restrict traceroute operations.
4. The destination network is configured to hide routing information.

Conclusion

The traceroute command was successfully executed; however, no routing information was obtained. The absence of responses suggests that network devices between the Kali Linux host and the destination IP address are filtering or blocking traceroute packets.

Screenshot Reference

Appendix A, Figure 1: Traceroute from Kali Linux to Host 2 (10.13.246.8) showing all hops returning "*" and no route information disclosed.

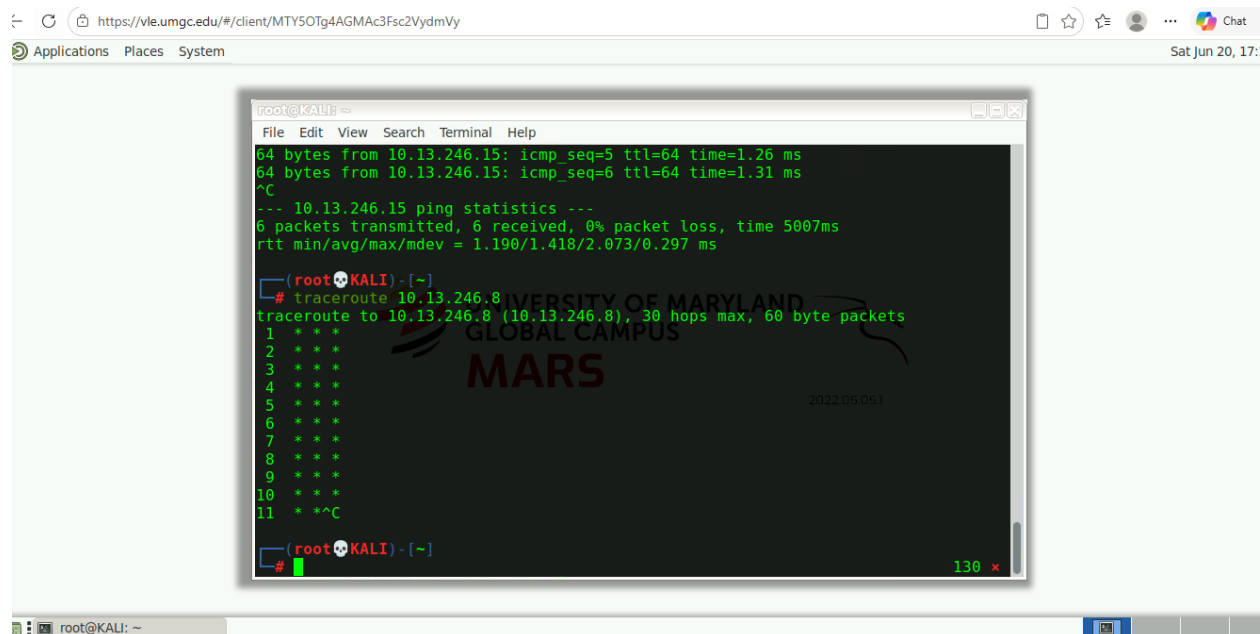


Figure A-7. Traceroute Results from Kali Linux to Host 2 (10.13.246.8)

A.6 Nmap Enumeration Results

A.6.1 Host Enumeration Scan

Objective

FICBANK Penetration Testing Plan & Report for FICBANK Enterprise Network

Version 5.0, July 27, 2026

Identify active hosts on the target network and determine which systems are responsive.

Command Executed

```
nmap 10.13.246.0/24
```

Results

The scan identified nine active hosts within the subnet. Several hosts exposed web services on ports 80 and 443. Host 10.13.246.15 additionally exposed SSH and Freeciv services.

Active Hosts Identified

IP Address
10.13.246.5
10.13.246.8
10.13.246.9
10.13.246.10
10.13.246.11
10.13.246.12
10.13.246.14
10.13.246.15
10.13.246.18

Analysis

The scan successfully identified active systems within the target subnet. The presence of multiple responsive hosts indicates that several systems are available for further assessment. The presence of SSH on Host 10.13.246.15 suggests administrative access capabilities, while HTTP and HTTPS services indicate web-based applications that may require additional security evaluation.

Conclusion

Nmap host enumeration successfully identified nine active hosts on the target network. These systems represent potential attack surfaces that should be further analyzed during service enumeration and vulnerability assessment activities.

Screenshot Reference

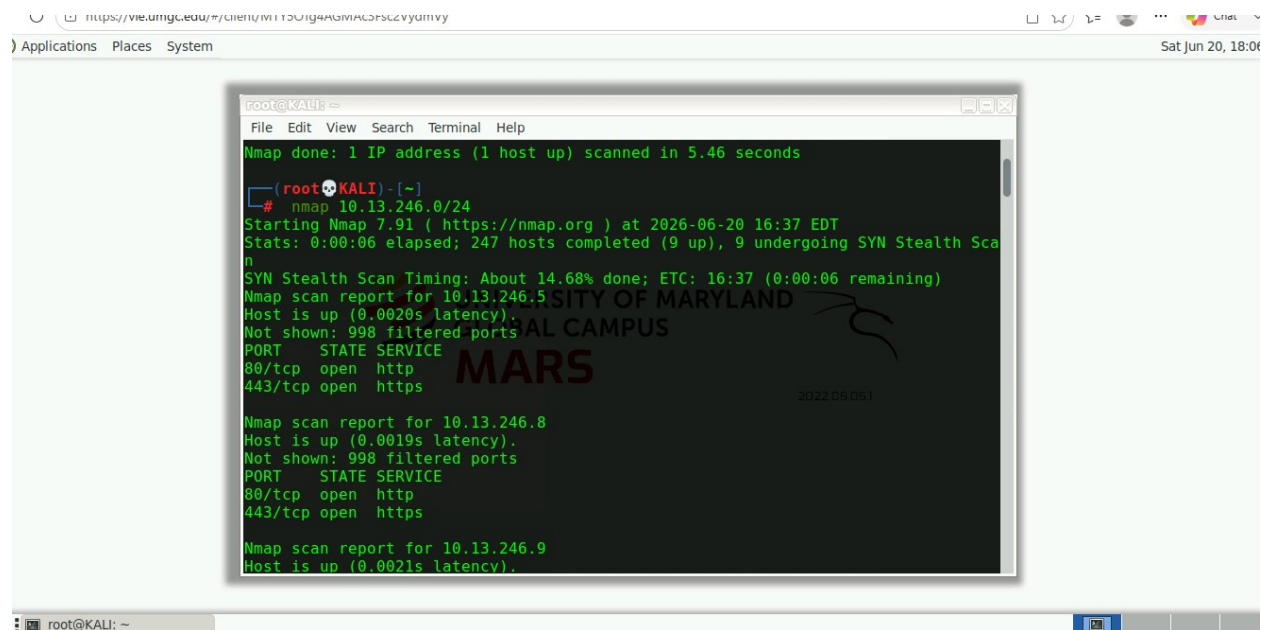


Figure A-8. Nmap Enumeration of the 10.13.246.0/24 Network

A.6.2 Service Enumeration Scan

Objective

Identify open ports and services running on discovered hosts.

Command Executed

nmap 10.13.246.0/24

Results

Host	Open Ports	Services
10.13.246.14	80, 443	HTTP, HTTPS
10.13.246.15	22, 80, 5555	SSH, HTTP, Freeciv
10.13.246.18	80, 443	HTTP, HTTPS

Analysis

The environment primarily supports web-based services. HTTPS availability on Hosts 10.13.246.14 and 10.13.246.18 provides encrypted communications, while Host 10.13.246.15 exposes SSH for remote administration. The presence of these services identifies potential entry points that should be assessed for vulnerabilities and configuration weaknesses.

Conclusion

Service enumeration successfully identified active services running on multiple hosts. The results demonstrate the presence of web servers and administrative services that warrant further security assessment.

Screenshot Reference

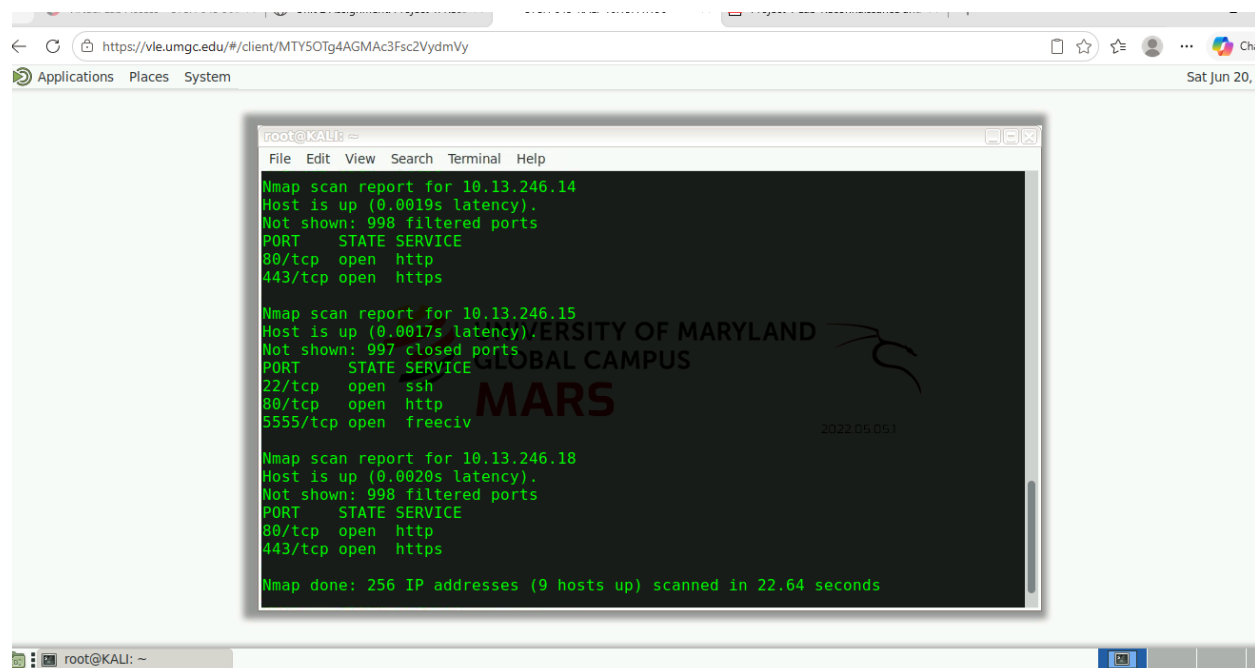


Figure A-9. Nmap Service Enumeration Results

A.7 Nmap Targeted Port and OS Detection Results

Objective

Perform a focused scan against Host 10.13.246.8 to identify open ports and attempt operating system detection.

Command Executed

```
nmap -p 21,23,53,80 -O -v 10.13.246.8
```

Results

Port	State	Service
21/tcp	Filtered	FTP
23/tcp	Filtered	Telnet
53/tcp	Filtered	DNS
80/tcp	Open	HTTP

Port	State	Service

Additional Findings

- Host Status: Online
- OS Detection: Inconclusive
- OS fingerprinting could not produce a reliable match.
- Insufficient port-state information was available for accurate operating system identification.

Analysis

The host is functioning as a web server with HTTP accessible on port 80. FTP, Telnet, and DNS services were filtered, suggesting the presence of firewall protections or access-control mechanisms. Because insufficient open and closed ports were available, Nmap could not accurately determine the operating system.

Conclusion

Nmap successfully identified active ports and services on Host 10.13.246.8. The results indicate a reduced attack surface due to filtered services, while the accessible HTTP service remains a potential target for further vulnerability assessment.

Screenshot Reference

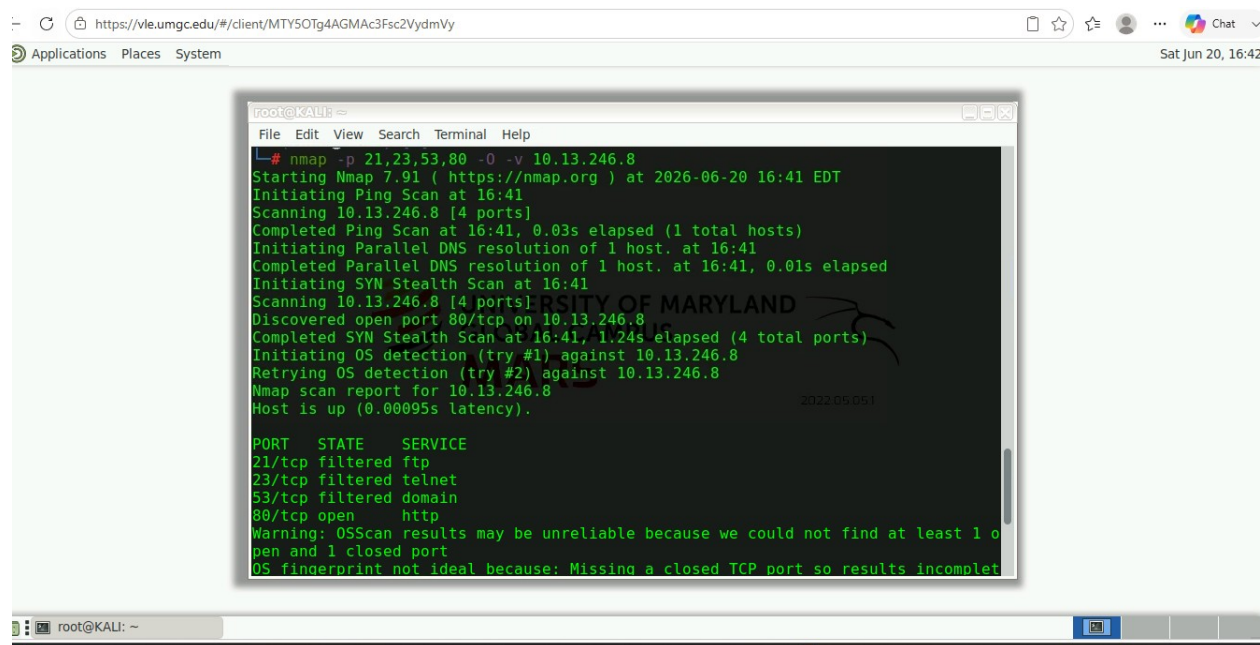


Figure A-10. Nmap Targeted Port and OS Detection Scan for 10.13.246.8

Security Findings and Potential Risks

1. HTTP Service Exposed on Port 80

- o Unencrypted traffic may be susceptible to interception.
- o Recommendation: Redirect HTTP traffic to HTTPS and enforce TLS encryption.

2. SSH Service Exposed on Host 10.13.246.15

- o Administrative services are common attack targets.
- o Recommendation: Enforce MFA, strong passwords, and IP restrictions.

3. Public DNS and WHOIS Information

- o Provides attackers with infrastructure intelligence.
- o Recommendation: Limit unnecessary public information and monitor DNS records.

4. Multiple Public-Facing Web Services

- o Web applications increase attack surface.
- o Recommendation: Perform routine vulnerability scanning and patch management.

5. Filtered Ports Indicate Security Controls

- o Positive security finding showing firewall protections are present.
- o Recommendation: Continue reviewing firewall rules and network segmentation.

Vulnerability Identification and Mitigation Recommendations

Several potential vulnerabilities and attack vectors were identified during the reconnaissance phase. Publicly accessible DNS information, domain registration details, active hosts, and exposed services provide valuable intelligence that could be leveraged by malicious actors. Although the scans did not identify exploitable vulnerabilities directly, the discovered services represent potential attack surfaces that warrant further assessment.

Recommended mitigation strategies include:

- Restrict unnecessary services and close unused ports.
- Implement firewalls and access control lists to limit network exposure.
- Enforce strong authentication and multi-factor authentication for administrative services such as SSH.
- Regularly update and patch operating systems and applications.
- Conduct routine vulnerability scans and penetration tests.

- Monitor DNS and domain registration records to minimize unnecessary information disclosure.
- Deploy intrusion detection and intrusion prevention systems to identify suspicious activity.
- Maintain security awareness training programs to reduce the effectiveness of social engineering attacks.

The tools utilized during this assessment, including Ping, Traceroute, Nmap, DIG, NSLOOKUP, and WHOIS, demonstrate fundamental penetration testing principles by collecting information that can be used to identify potential weaknesses and evaluate an organization's security posture.

Reconnaissance and Enumeration Questions

1. How might publicly accessible information gathered during reconnaissance and enumeration further some or all of the pen testing goals?

Publicly accessible information gathered during reconnaissance and enumeration helps penetration testers identify potential attack surfaces before conducting active testing. Information such as IP addresses, domain names, DNS records, email addresses, open ports, and network services allows testers to map the target environment and identify systems that may be vulnerable to attack. In this project, tools such as DIG, NSLOOKUP, WHOIS, Nmap, and ping sweeps revealed active hosts, DNS records, domain registration information, and accessible services. This information supports penetration testing goals by helping testers identify targets, prioritize vulnerabilities, and develop an effective testing strategy while minimizing unnecessary network traffic.

2. How do you think performing advanced searches with Google search engines and command-line search tools facilitates penetration testing by IT/cybersecurity professionals?

Advanced search techniques and command-line reconnaissance tools enable cybersecurity professionals to gather information quickly and efficiently. Search engines can reveal publicly exposed documents, employee information, technology stacks, and configuration details that may be useful during an assessment. Command-line tools such as DIG, NSLOOKUP, WHOIS, and Nmap provide technical details about DNS infrastructure, IP addresses, open ports, and services running on target systems. These tools help security professionals understand the target environment and identify potential weaknesses before performing more advanced testing activities.

4. How can the search techniques be used by both black hat and white hat hackers?

Both black hat and white hat hackers use similar reconnaissance techniques; however, their intentions differ. White hat hackers use reconnaissance and enumeration to identify vulnerabilities and improve security within an organization's systems. Black hat hackers use the same information to locate weaknesses that can be exploited for unauthorized access, data theft, or disruption of services. For example, DNS records, open ports, and publicly available contact information may help security professionals identify risks, while malicious actors may use the same information to conduct phishing attacks, reconnaissance, or intrusion attempts.

6. What is the difference between active reconnaissance and passive reconnaissance?

Passive reconnaissance involves gathering information about a target without directly interacting with the target's systems. Examples include reviewing websites, social media platforms, public records, search engines, WHOIS databases, and DNS information. Active reconnaissance involves directly interacting with target systems to gather information. Examples include ping sweeps, traceroute operations, port scans, service enumeration, and vulnerability scans. Active reconnaissance generally provides more detailed information but is more likely to be detected by monitoring systems and security controls.

7. What can you say about the results when scanning multiple hosts and/or a subnet compared with the individual host scans?

Scanning an entire subnet provides a broad view of the network and helps identify all active hosts within a given address range. During this project, the subnet scan identified nine active hosts on the 10.13.246.0/24 network. Individual host scans provide more detailed information about a specific system, including open ports, running services, and operating system characteristics. Subnet scans are useful for identifying targets, while individual host scans are useful for gathering detailed technical information needed for vulnerability analysis and penetration testing.

8. Recommend a good mitigation strategy to address any vulnerabilities identified.

Several mitigation strategies can help reduce the risks identified during reconnaissance and enumeration. Organizations should implement firewalls and access control lists to restrict unnecessary network access, disable unused services, and ensure only required ports are exposed. Regular vulnerability assessments and patch management should be conducted to keep systems updated and protected from known vulnerabilities. DNS records and WHOIS information should be reviewed to ensure sensitive information is not unnecessarily exposed. Additionally, organizations should implement network monitoring, intrusion detection systems, and security awareness training to help identify and prevent unauthorized access attempts.

Conclusion

The reconnaissance activities conducted during this assessment successfully identified active hosts, network paths, DNS records, domain information, and exposed services within the target environment. Tools including Ping, Traceroute, Nmap, DIG, NSLOOKUP, and WHOIS provided valuable information that can support future vulnerability assessments and penetration testing activities. The findings demonstrate the importance of reconnaissance as the foundation of a security assessment and highlight the need for continuous monitoring, vulnerability management, and risk mitigation practices to reduce organizational exposure to cyber threats.

4.2. Appendix B – Vulnerability Discovery Phase

Figure B-1. Nmap Host Discovery (Ping Sweep)

Objective

Perform a host discovery scan to identify all active systems on the DVWA subnet prior to conducting detailed vulnerability discovery and service enumeration.

Command Executed

nmap -sn 10.13.246.0/24

Results

The host discovery scan identified **nine (9)** active hosts on the target subnet.

Host	IP Address	Status
Host 1	10.13.246.5	Up
Host 2	10.13.246.8	Up
Host 3	10.13.246.9	Up
Host 4	10.13.246.10	Up
Host 5	10.13.246.11	Up
Host 6	10.13.246.12	Up
Host 7	10.13.246.14	Up
Host 8	10.13.246.15	Up
Host 9	10.13.246.18	Up

Analysis

The Nmap host discovery scan successfully established the current network baseline by identifying nine active systems within the **10.13.246.0/24** subnet. The scan completed in **4.73 seconds** and confirmed that each discovered host was reachable. Since the **-sn** option performs only host discovery, no port or service information was collected during this phase. The identified systems provide the scope for subsequent port scanning, service enumeration, and vulnerability assessment activities.

Evidence

Figure B-1. Nmap Host Discovery Scan of the DVWA Network

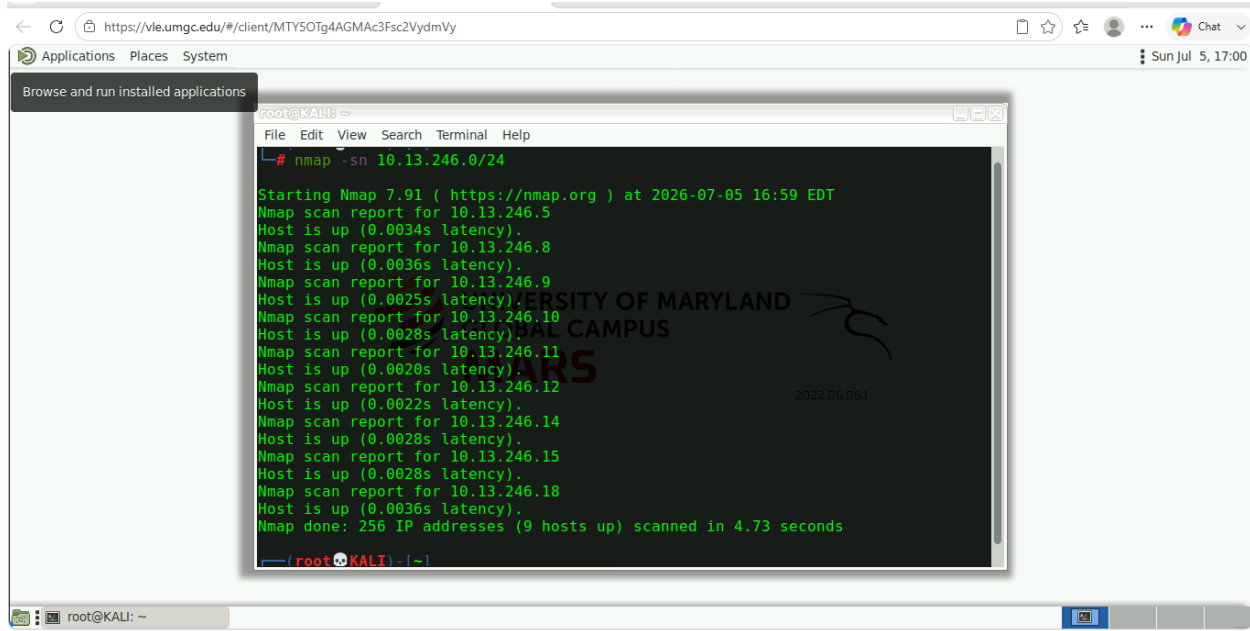


Figure B-2. Nmap Network Port and Service Discovery

Objective

Identify open TCP ports and the network services running on each active host discovered during the host discovery phase. Enumerating exposed services helps identify potential entry points for vulnerability assessment and penetration testing.

Command Executed

```
nmap 10.13.246.0/24
```

Results

The network scan successfully identified multiple active hosts exposing HTTP and HTTPS services. Most systems presented standard web services over ports **80** and **443**, while one system (10.13.246.15) also exposed an **SSH** service on port **22**. Port **5555** was detected as filtered, indicating that traffic was being blocked by a firewall or filtering device.

Host	Open Ports	Services
10.13.246.5	80, 443	HTTP, HTTPS
10.13.246.8	80, 443	HTTP, HTTPS
10.13.246.9	80, 443	HTTP, HTTPS
10.13.246.10	80, 443	HTTP, HTTPS
10.13.246.11	80, 443	HTTP, HTTPS

Host	Open Ports	Services
10.13.246.12	80, 443	HTTP, HTTPS
10.13.246.14	80, 443	HTTP, HTTPS
10.13.246.15	22, 80, 5555 (filtered)	SSH, HTTP, Freeciv (filtered)

Analysis

The port discovery scan expanded upon the initial host discovery by identifying the services exposed by each active system. Nearly every host provided web services through HTTP (TCP 80) and HTTPS (TCP 443), suggesting that web applications represent the primary attack surface within the laboratory environment. The discovery of SSH (TCP 22) on host **10.13.246.15** indicates that remote administrative access is enabled on that system and should be evaluated for secure configuration. Port **5555** was identified as filtered, demonstrating that network filtering controls are present and restricting direct access to that service.

Evidence

Figure B-2. Nmap Scan Showing Open Ports and Services on the DVWA Network

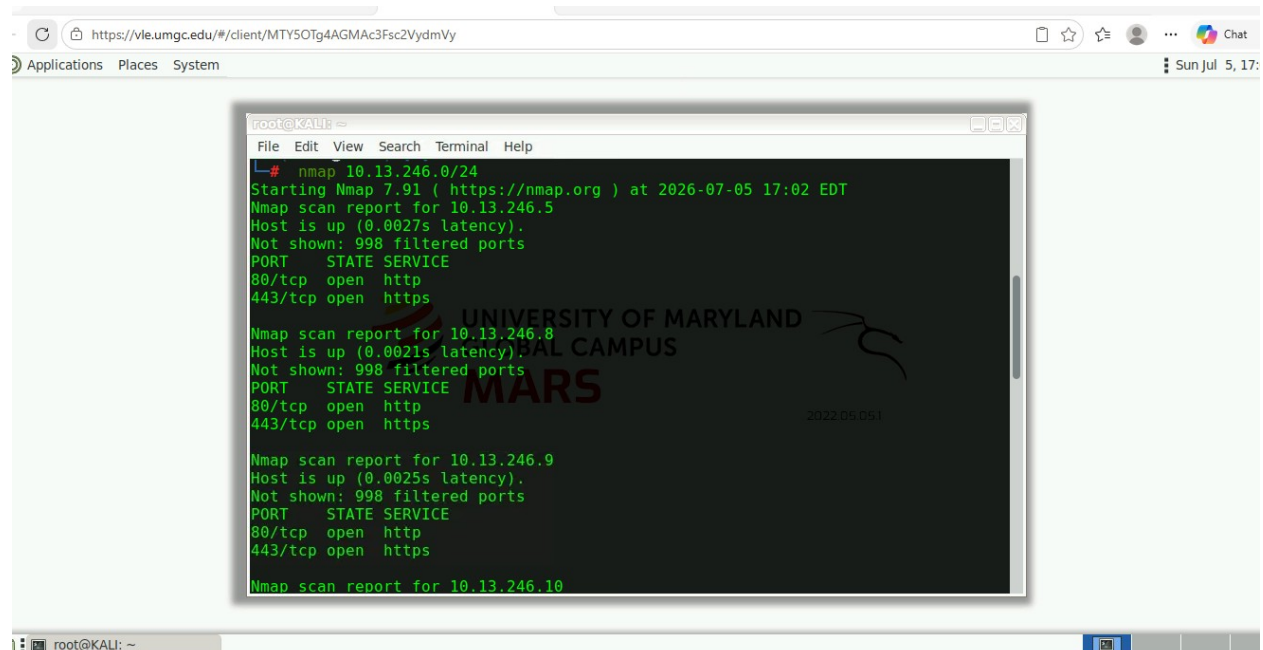


Figure B-3. Nmap Operating System Detection and Service Enumeration

Objective

Perform operating system detection and service enumeration to identify the operating system characteristics and network services running on the target hosts.

Command Executed

```
nmap -O -v 10.13.246.1-15
```

Results

The verbose operating system scan successfully enumerated the services running on the active hosts while attempting operating system fingerprinting. For host **10.13.246.15**, Nmap identified:

Host	Open Ports	Service
10.13.246.15	22/TCP	SSH
10.13.246.15	80/TCP	HTTP
10.13.246.15	5555/TCP	Filtered (Freeciv)

The OS fingerprint suggested the target is most likely running a **Linux-based operating system**, with several possible Linux kernel versions reported. Nmap indicated that an exact operating system match could not be determined because insufficient TCP fingerprint information was available.

Analysis

Operating system detection provides valuable intelligence regarding the technologies deployed within the target environment. Although Nmap was unable to determine the precise operating system, the scan strongly suggested a Linux platform based on the TCP/IP fingerprint. This information allows penetration testers to narrow subsequent vulnerability assessments to Linux-specific vulnerabilities and configurations. The presence of SSH and HTTP services further identifies administrative and web application attack surfaces that warrant additional testing during later phases of the assessment.

Evidence

Figure B-3. Nmap Operating System Detection and Verbose Service Enumeration

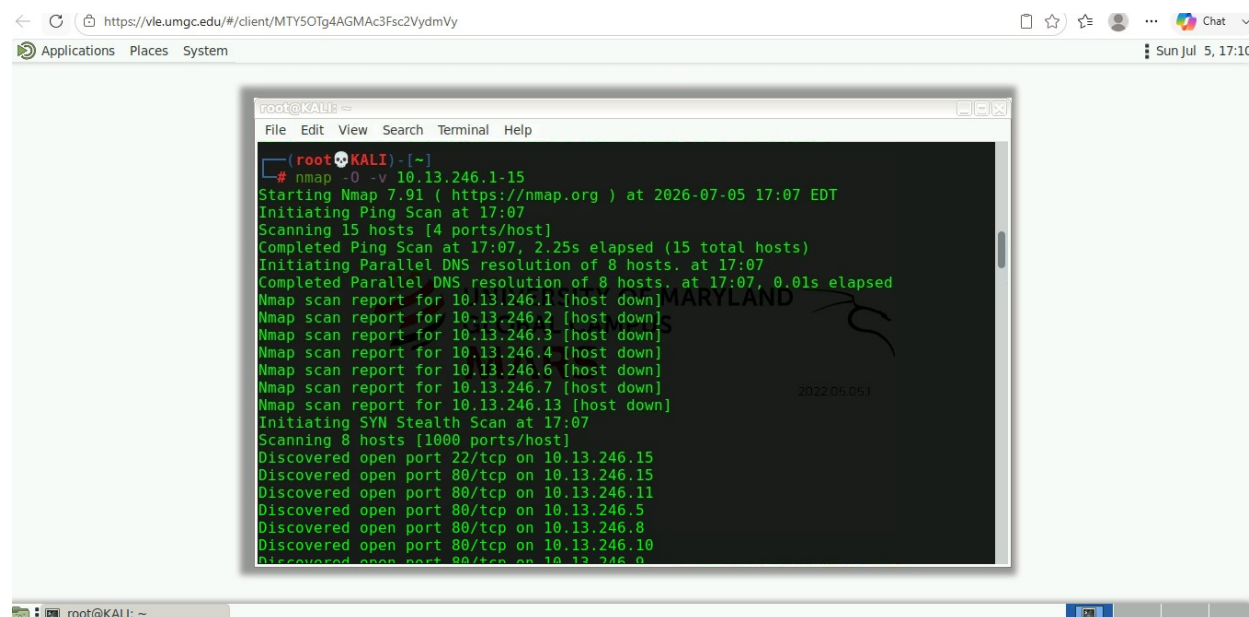


Figure B-4. DIRB Directory Enumeration

Objective

Perform directory enumeration against the DVWA web application to identify hidden directories, files, and resources that may expose sensitive information or increase the application's attack surface.

Command Executed

```
dirb http://umgc-web-dvwa.azurewebsites.net
```

Results

DIRB successfully enumerated several publicly accessible directories and files.

Directories Discovered

- /config/
- /docs/
- /external/

Files Discovered

- /favicon.ico
- /index.php
- /php.ini
- /phpinfo.php

- /robots.txt
- /server-status (*HTTP 403 Forbidden*)

Analysis

The directory enumeration identified several accessible directories that could reveal application configuration files, documentation, or externally accessible resources. Although access to /server-status was denied (HTTP 403), its presence indicates that server status functionality exists and should remain properly restricted. Files such as php.ini, phpinfo.php, and robots.txt may disclose valuable information about the server environment if improperly configured, making them useful targets during vulnerability assessments.

Evidence

Figure B-4. DIRB Directory Enumeration Results

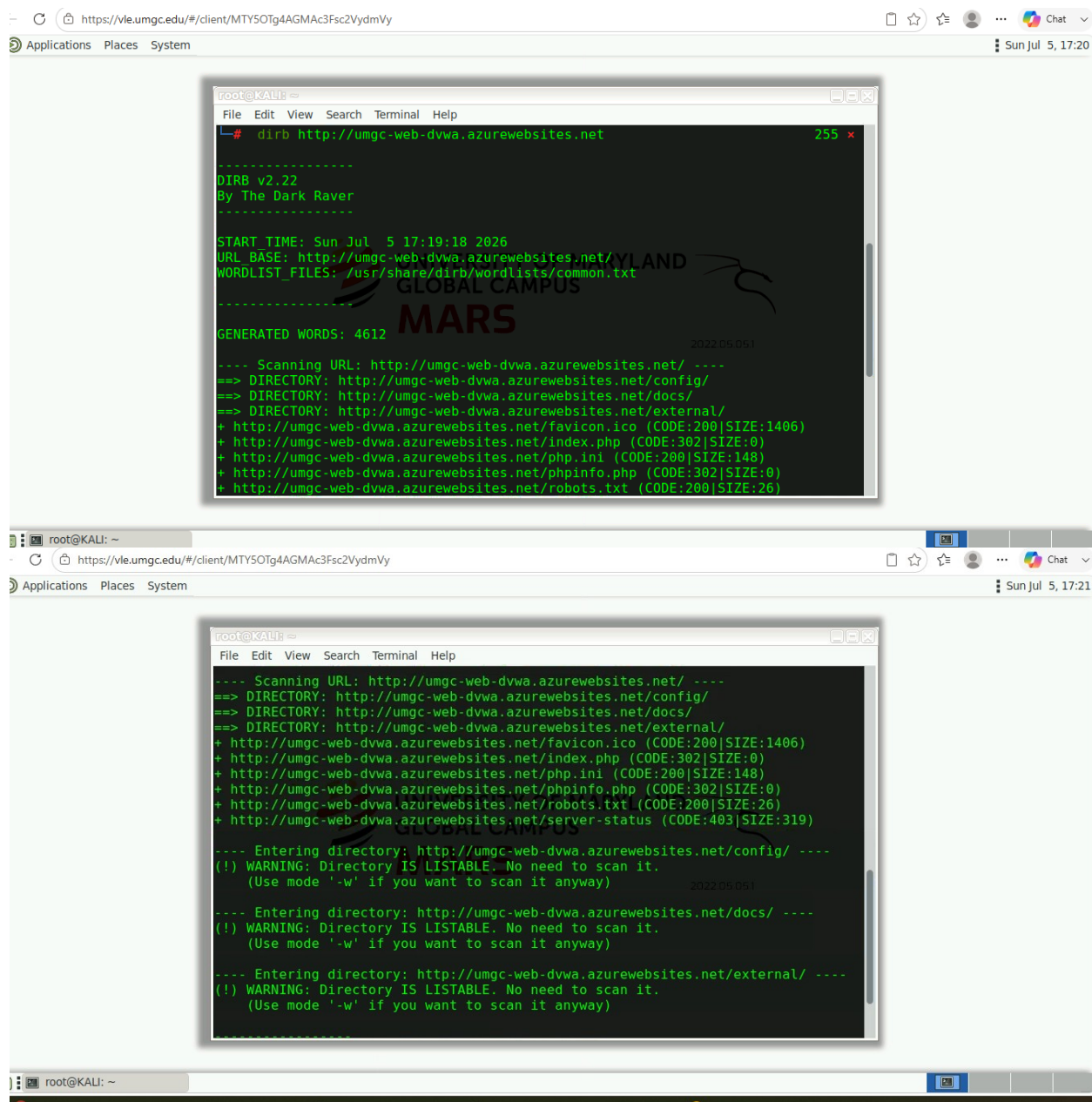


Figure B-5. Nikto Web Server Vulnerability Scan

Objective

Perform a web server vulnerability assessment using Nikto to identify insecure configurations, missing security controls, and potential weaknesses in the target web server.

Command Executed

```
nikto -h http://10.13.246.8
```

Results

Nikto completed the scan successfully and identified several security configuration issues.

Findings

- No web server banner disclosed.
- Missing **X-Frame-Options** header.
- Missing **X-XSS-Protection** header.
- Missing **X-Content-Type-Options** header.
- No CGI directories detected.
- 7,914 HTTP requests performed.
- 3 informational findings reported.
- No critical vulnerabilities identified.

Analysis

Nikto detected several missing HTTP security headers that are considered web application security best practices. These headers help protect against clickjacking attacks, reflected cross-site scripting (XSS), and MIME-type sniffing attacks. While these findings are classified as informational rather than critical, implementing the missing headers would strengthen the overall security posture of the web application.

Evidence

Figure B-5. Nikto Web Server Scan Results

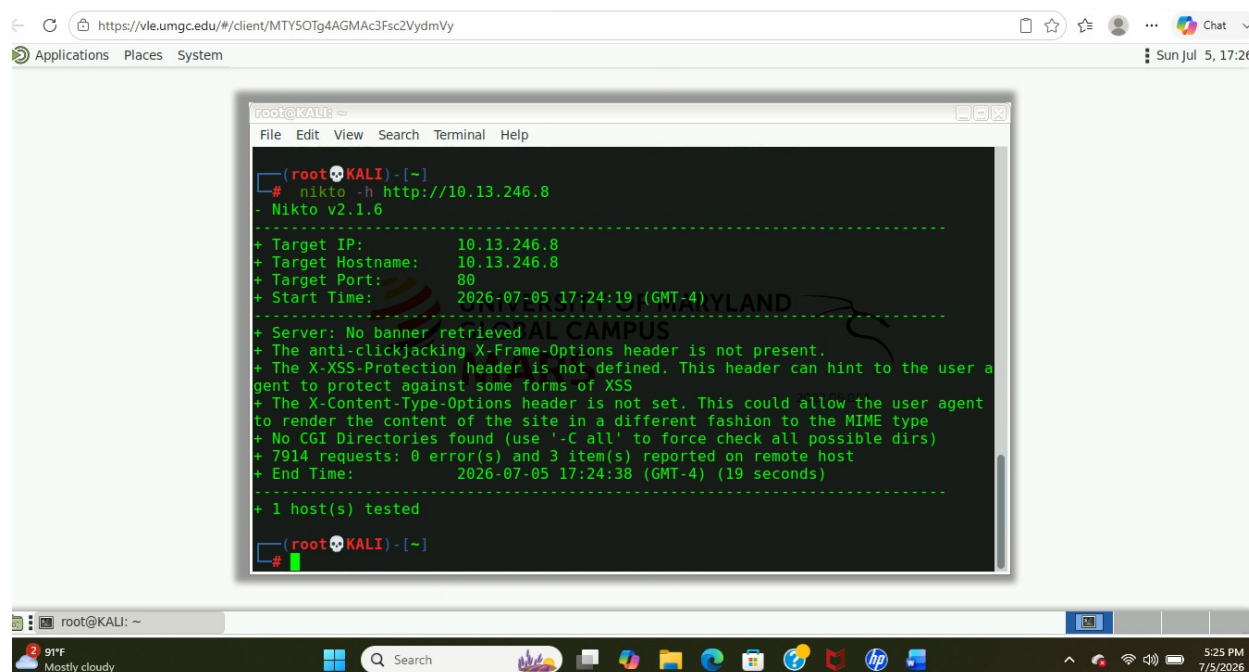


Figure B-6. WPScan Assessment

Objective

Determine whether the target web application is running WordPress and identify any WordPress-specific vulnerabilities if present.

Command Executed

```
wpscan --url http://10.13.246.8
```

Results

WPScan successfully connected to the target but determined that the application is **not running WordPress**. As a result, the scan terminated without performing WordPress-specific vulnerability enumeration.

Analysis

WPScan confirmed that the target application is not based on the WordPress content management system. This result demonstrates the importance of identifying the underlying technology before conducting specialized vulnerability assessments. Since WordPress was not detected, WordPress-specific exploits and plugin enumeration were not applicable to this target.

Evidence

Figure B-6. WPScan Results Showing No WordPress Installation Detected

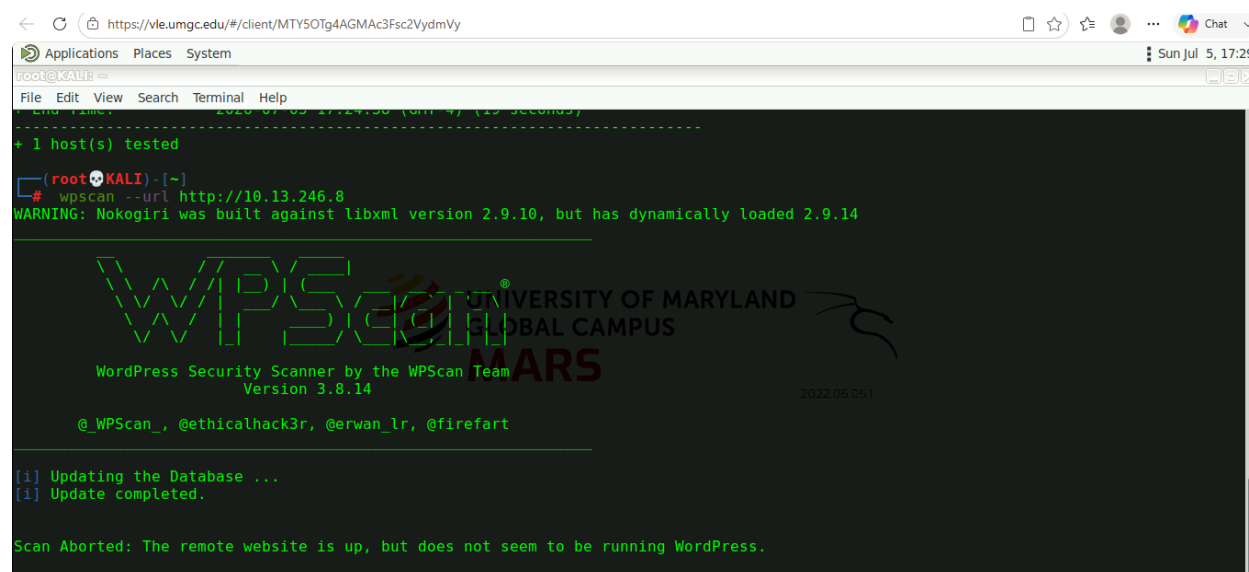


Figure B-7. OpenVAS Vulnerability Assessment

Objective

Perform an automated vulnerability assessment using Greenbone/OpenVAS to identify known security weaknesses, misconfigurations, and cryptographic issues affecting the target system.

Tool Used

Greenbone Security Assistant (OpenVAS)

Target

10.15.41.196

Scan Results

Severity	Vulnerability	Affected Service
High (10.0)	Report Outdated / End-of-Life Scan Engine / Environment (Local)	general/tcp
Medium (5.9)	SSL/TLS: Weak Cipher Suites	TCP 3389
Low (2.6)	Weak MAC Algorithm(s) Supported (SSH)	TCP 22

Findings Summary

High Severity

- Report Outdated / End-of-Life Scan Engine / Environment (Local)
 - Indicates that the scanning engine or environment is outdated and should be updated to ensure accurate vulnerability detection.

Medium Severity

- SSL/TLS Weak Cipher Suites
 - The remote service supports outdated or weak encryption algorithms that could reduce the confidentiality of encrypted communications.

Low Severity

- Weak SSH MAC Algorithms
 - The SSH service supports weaker message authentication algorithms that should be replaced with stronger cryptographic options.

Analysis

The OpenVAS assessment successfully identified several security weaknesses associated with the target system's cryptographic configuration. The most significant finding related to the scan environment itself, indicating that the vulnerability detection engine should be kept current to ensure comprehensive and accurate assessments. The SSL/TLS and SSH findings suggest that older cryptographic algorithms remain enabled on the target host. Although these vulnerabilities are not immediately critical, implementing stronger cipher suites and modern SSH MAC algorithms would improve the confidentiality and integrity of network communications while aligning the system with current security best practices.

Recommendations

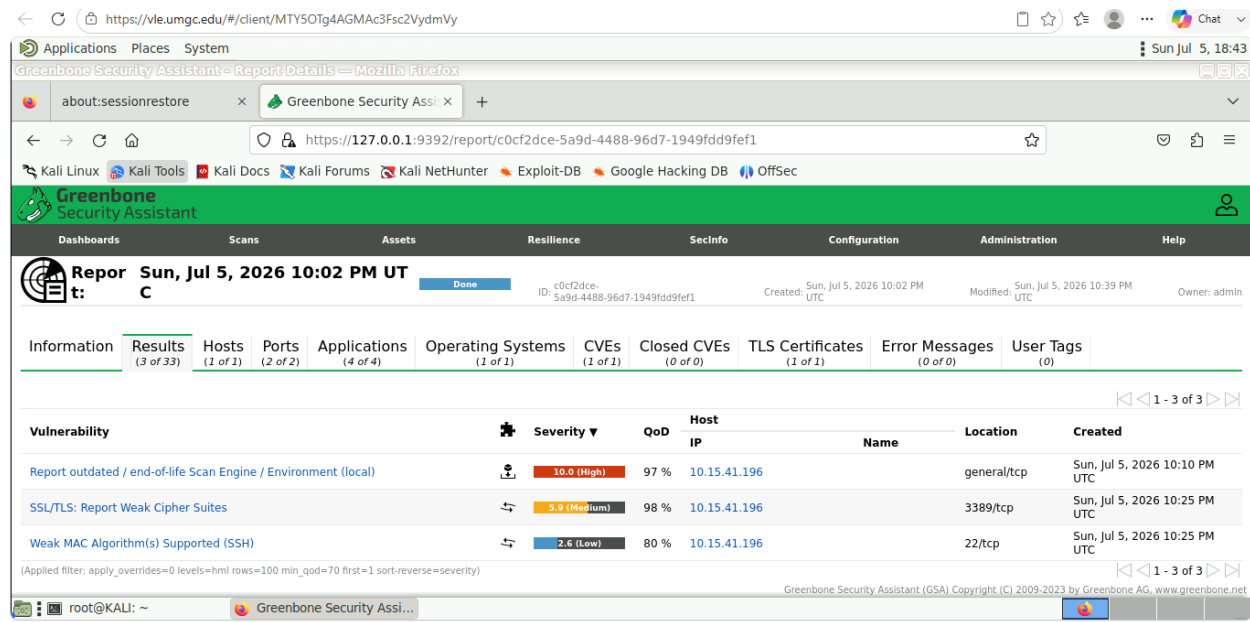
1. Update the Greenbone/OpenVAS scan engine and vulnerability feeds to the latest supported version.
2. Disable deprecated SSL/TLS cipher suites and enable only strong, modern encryption algorithms (such as TLS 1.2 and TLS 1.3 with recommended cipher suites).
3. Configure the SSH service to disable weak MAC algorithms and use stronger alternatives such as hmac-sha2-256 or hmac-sha2-512.
4. Perform periodic vulnerability scans after remediation to verify that the identified issues have been resolved.

Evidence

Figure B-7. Greenbone/OpenVAS Vulnerability Assessment Results

FICBANK Penetration Testing Plan & Report for FICBANK Enterprise Network

Version 5.0, July 27, 2026



Vulnerability	Severity	QoD	Host IP	Name	Location	Created
Report outdated / end-of-life Scan Engine / Environment (local)	10.0 (High)	97 %	10.15.41.196		general/tcp	Sun, Jul 5, 2026 10:10 PM UTC
SSL/TLS: Report Weak Cipher Suites	5.9 (Medium)	98 %	10.15.41.196		3389/tcp	Sun, Jul 5, 2026 10:25 PM UTC
Weak MAC Algorithm(s) Supported (SSH)	2.6 (Low)	80 %	10.15.41.196		22/tcp	Sun, Jul 5, 2026 10:25 PM UTC

Questions

1. What can you say about the impact of these vulnerabilities from the different scans and how do they relate to risk assessment?

The scan results show that the target environment has several areas of risk, especially exposed web services, weak security headers, weak SSL/TLS cipher suites, and weak SSH MAC algorithms. These findings help support the risk assessment process because they identify which systems and services are most exposed and which issues should be prioritized for remediation. Higher-severity findings, such as the outdated scan engine/environment and weak encryption configurations, should receive greater attention because they may affect the accuracy of scanning or the confidentiality and integrity of communications.

2. Is vulnerability scanning invasive or noninvasive?

Vulnerability scanning can be either noninvasive or invasive depending on the scan type and settings used. In this lab, most scans were noninvasive because tools such as Nmap, DIRB, Nikto, WPScan, and OpenVAS primarily identified open ports, services, directories, missing headers, and known weaknesses without exploiting the target system. However, vulnerability scanning can become more invasive if aggressive scripts, exploit checks, brute-force testing, or authenticated scans are enabled.

3. Provide an alternative mitigation strategy for improvement, other than the one provided by the scan results.

An alternative mitigation strategy would be to implement a formal vulnerability management process. This should include regular authenticated scans, monthly feed updates, patch validation, risk-based prioritization, and documented remediation tracking. In addition, the organization

should harden web and SSH services by disabling weak cryptographic algorithms, enforcing modern TLS settings, restricting SSH access, and reviewing exposed directories such as `/config/`, `/docs/`, and `/external/`.

6. Were there any identified open ports, known exploits, unauthorized file access, or web vulnerabilities?

Yes. Nmap identified open ports including HTTP on TCP 80, HTTPS on TCP 443, and SSH on TCP 22. DIRB identified accessible web directories and files such as `/config/`, `/docs/`, `/external/`, `php.ini`, `phpinfo.php`, and `robots.txt`. Nikto identified missing web security headers, including `X-Frame-Options`, `X-XSS-Protection`, and `X-Content-Type-Options`. OpenVAS identified weak SSL/TLS cipher suites and weak SSH MAC algorithms. No confirmed SQL injection or cross-site scripting exploit was shown in the scan results, but the findings indicate areas that require further manual testing.

10. Which of the tools used during this phase yielded the most useful results?

OpenVAS and Nmap produced the most useful results. Nmap was useful because it identified live hosts, open ports, and exposed services, which helped define the attack surface. OpenVAS was useful because it assigned severity levels to vulnerabilities and helped prioritize remediation. DIRB was also valuable because it identified exposed directories and files on the web application, while Nikto provided useful web server configuration findings. WPScan was less useful in this case because the target was not running WordPress.

Conclusion

The vulnerability discovery phase successfully expanded upon the reconnaissance activities completed in Project 1 by identifying active hosts, exposed services, web application resources, and known security weaknesses within the target environment. Using Nmap, DIRB, Nikto, WPScan, and OpenVAS provided a comprehensive assessment of the organization's attack surface from multiple perspectives. These tools identified active systems, open ports, accessible web directories, missing HTTP security headers, weak cryptographic configurations, and additional vulnerabilities requiring remediation.

The results demonstrate the importance of combining multiple discovery tools to obtain a complete understanding of an organization's security posture. While no critical application-level vulnerabilities, such as SQL injection or cross-site scripting, were confirmed during this phase, the assessment revealed several configuration weaknesses that could increase risk if left unaddressed. Implementing the recommended security improvements, including strengthening cryptographic settings, applying security headers, restricting unnecessary services, and maintaining an effective vulnerability management program, would significantly reduce the organization's attack surface.

The active and passive reconnaissance activities completed during Project 1 established an understanding of the target environment, while the discovery activities performed in Project 2

expanded that understanding by identifying live hosts, exposed services, web resources, and known vulnerabilities. Together, these phases provide the information necessary to support subsequent penetration testing activities, including exploitation, validation, and remediation.

Overall, the discovery phase established a solid foundation for the remaining stages of the penetration test by identifying potential attack vectors and prioritizing systems that require further security evaluation. These findings will support subsequent exploitation, validation, and remediation activities while helping the organization improve its overall cybersecurity posture.

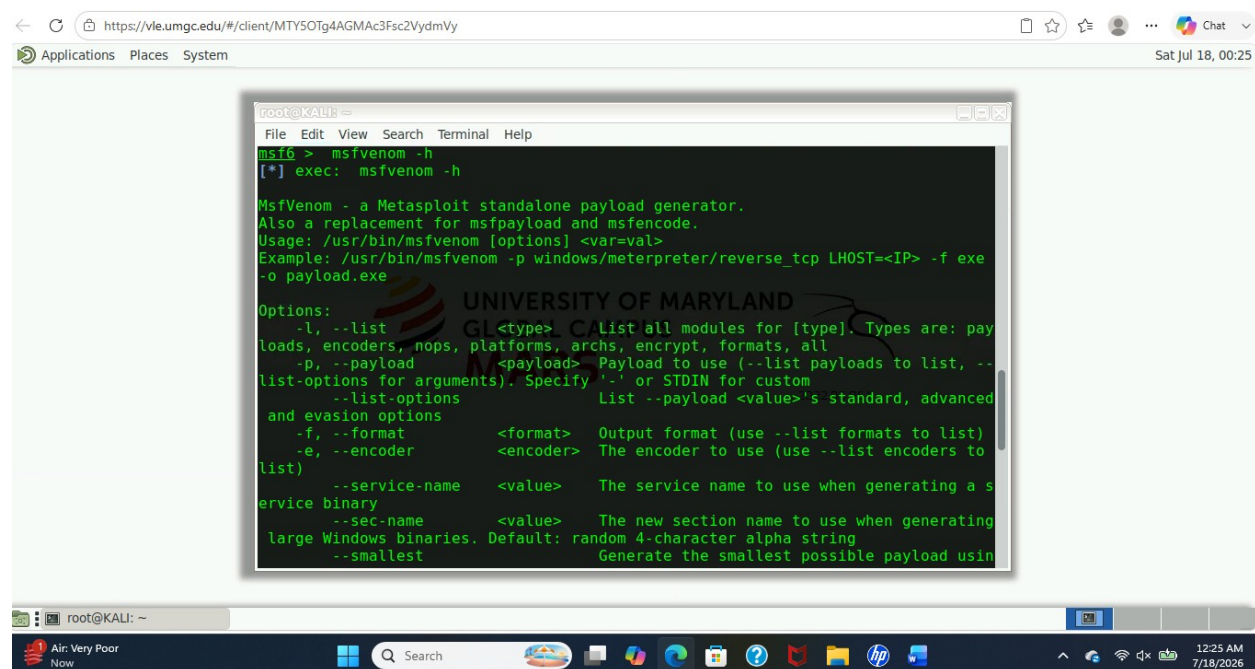
4.3. Appendix C – Exploitation Phase

C.1 Metasploit Framework (MSF)

The exploitation phase began by launching the Metasploit Framework (MSF) to validate the availability of exploit modules and payload generation capabilities. The `msfvenom -h` command was executed to display the available payload formats, encoders, platforms, architectures, and output options supported by the framework. This verified that the penetration testing environment was properly configured for payload creation and exploitation activities.

Next, the search `vsftpd` command was executed to identify exploits related to the vulnerable VSFTPD service discovered during the vulnerability assessment phase. Metasploit returned the `exploit/unix/ftp/vsftpd_234_backdoor` module, which targets the known VSFTPD version 2.3.4 backdoor vulnerability. The module received an **Excellent** reliability ranking, indicating that it is a well-tested exploit suitable for use in authorized penetration testing environments.

Figure C-1. Metasploit `msfvenom` help output.



```

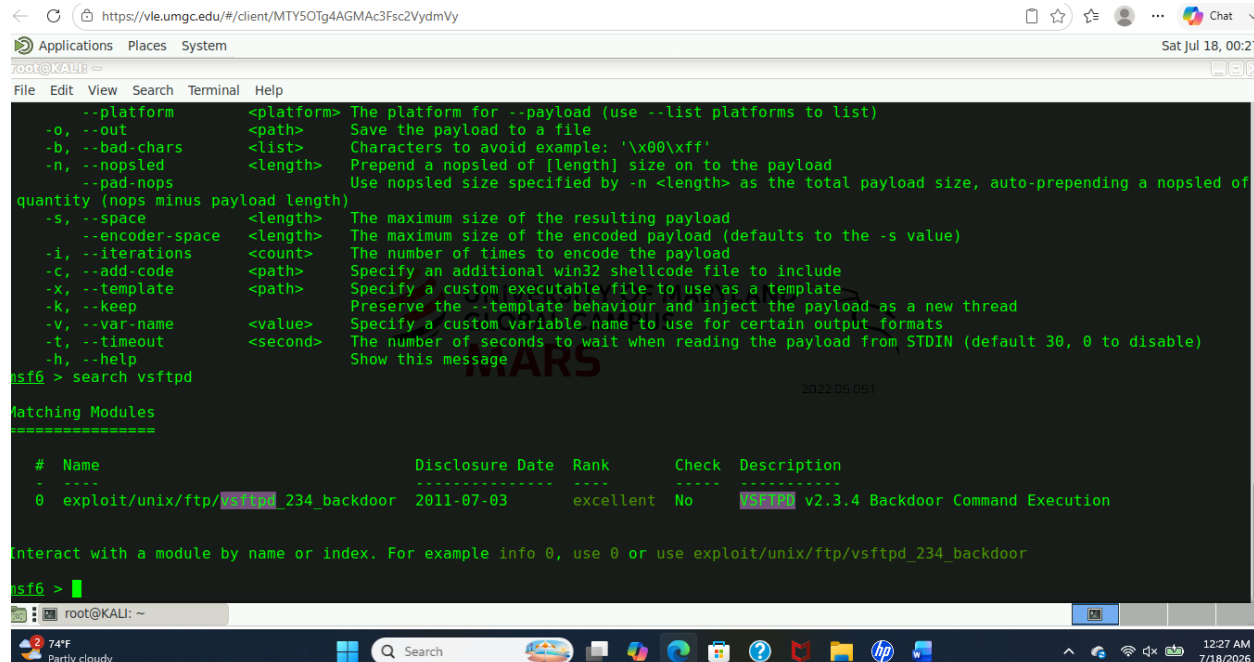
root@KALI: ~
File Edit View Search Terminal Help
msf6 > msfvenom -h
[*] exec: msfvenom -h

MsfVenom - a Metasploit standalone payload generator.
Also a replacement for msfpayload and msfencode.
Usage: /usr/bin/msfvenom [options] <var=val>
Example: /usr/bin/msfvenom -p windows/meterpreter/reverse_tcp LHOST=<IP> -f exe -o payload.exe

Options:
  -l, --list <type>      List all modules for [type]. Types are: pay
                        loads, encoders, nops, platforms, archs, encrypt, formats, all
  -p, --payload <payload> Payload to use (--list payloads to list, --
                        list-options for arguments). Specify '-' or STDIN for custom
                        --list-options      List --payload <value>'s standard, advanced
                        and evasion options
  -f, --format <format>  Output format (use --list formats to list)
  -e, --encoder <encoder> The encoder to use (use --list encoders to
                        list)
  --service-name <value> The service name to use when generating a s
                        ervice binary
  --sec-name <value>     The new section name to use when generating
                        large Windows binaries. Default: random 4-character alpha string
  --smallest             Generate the smallest possible payload usin

```


Figure C-2. Search results for the VSFTPD v2.3.4 exploit module.



```

root@KALI: ~
File Edit View Search Terminal Help
--platform <platform> The platform for --payload (use --list platforms to list)
-o, --out <path> Save the payload to a file
-b, --bad-chars <list> Characters to avoid example: '\x00\xff'
-n, --nopsled <length> Prepend a nopsled of [length] size on to the payload
--pad-nops Use nopsled size specified by -n <length> as the total payload size, auto-prepend a nopsled of
quantity (nops minus payload length)
-s, --space <length> The maximum size of the resulting payload
--encoder-space <length> The maximum size of the encoded payload (defaults to the -s value)
-i, --iterations <count> The number of times to encode the payload
-c, --add-code <path> Specify an additional win32 shellcode file to include
-x, --template <path> Specify a custom executable file to use as a template
-k, --keep Preserve the --template behaviour and inject the payload as a new thread
-v, --var-name <value> Specify a custom variable name to use for certain output formats
-t, --timeout <second> The number of seconds to wait when reading the payload from STDIN (default 30, 0 to disable)
-h, --help Show this message

msf6 > search vsftpd
2022-05-05

Matching Modules
=====

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 >

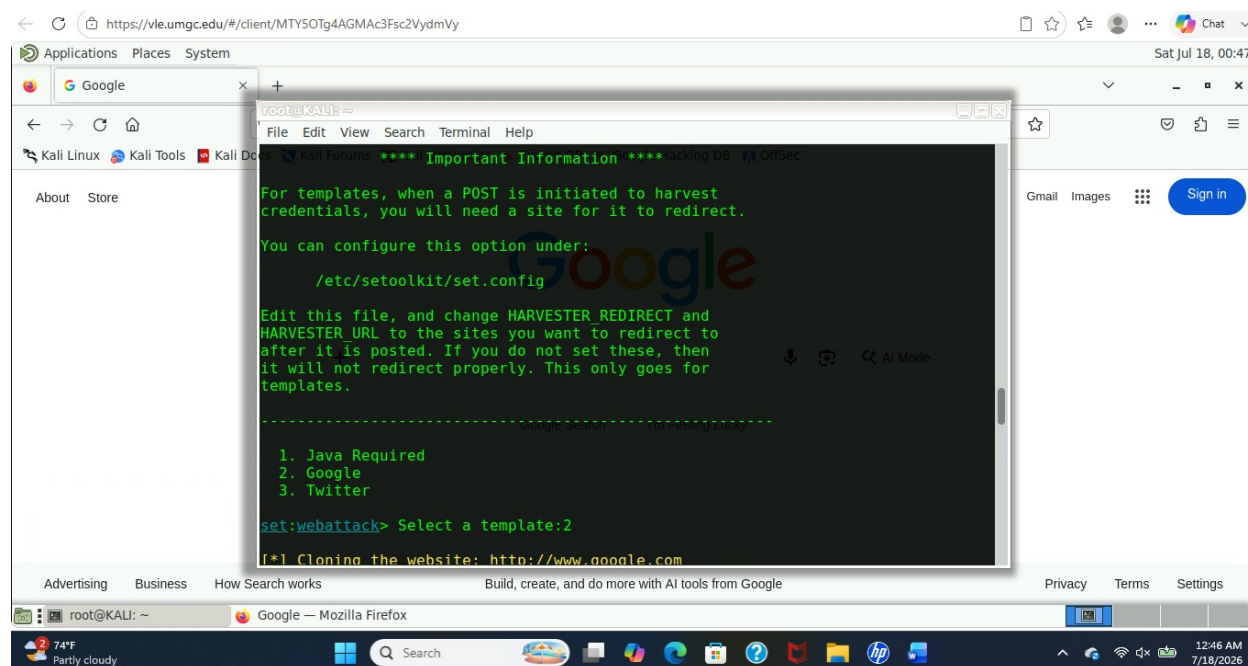
```

C.2 Social Engineering Toolkit (SET)

The Social Engineering Toolkit (SET) was used to demonstrate a phishing attack through the Credential Harvester module. The Web Attack option was selected, followed by the Credential Harvester attack method. SET cloned the Google login page and configured a local web server to present the cloned webpage to users.

During the configuration process, SET displayed instructions for configuring optional redirect settings after credentials were submitted. This demonstrated how attackers can create convincing phishing pages that closely resemble legitimate websites in order to collect user credentials.

Figure C-3. Social Engineering Toolkit configured to clone the Google login page.



C.3 Credential Harvesting Results

After the phishing page was successfully deployed, test credentials were entered into the cloned Google login page. The Credential Harvester captured the submitted email address and password and displayed them in the terminal window. This confirmed that the phishing simulation successfully intercepted user-supplied credentials.

This exercise was performed entirely within the authorized UMGC laboratory environment for educational purposes. No production systems or real user accounts were targeted.

Figure C-4. Credential Harvester evidence omitted from the public portfolio version to prevent disclosure of test credentials.

1. Based on your pen testing experience gained in this lab, what can you do to ensure that your client organization incorporates pen testing as part of its implementation procedures or security awareness program to ensure optimum internal or external security?

Based on this lab, I would recommend that the client organization incorporate penetration testing into its system development life cycle (SDLC) and change management process before deploying new systems into production. Regular internal and external penetration tests should be conducted after major system updates, infrastructure changes, or new application deployments to identify vulnerabilities before attackers can exploit them. In addition, the organization should implement ongoing security awareness training that includes phishing simulations and social engineering exercises similar to those performed with the Social Engineering Toolkit (SET). These activities help employees recognize phishing attempts while allowing security teams to measure user awareness and improve organizational security posture. Combining regular penetration testing with continuous security awareness training provides a proactive approach to reducing cybersecurity risks.

2. Assuming you are a member of a pen testing team, and you identify vulnerabilities and exploits in your client's network, should you obtain written permission prior to compromising the known vulnerability? Why or why not in terms of rules of engagement?

Yes. Written authorization must always be obtained before attempting to exploit any identified vulnerability. The Rules of Engagement (RoE) define the scope, objectives, testing methods, authorized systems, testing windows, and acceptable levels of risk for a penetration test. Even if a vulnerability is known, exploiting it without explicit authorization could disrupt business operations, damage systems, or violate contractual and legal requirements. The Rules of Engagement protect both the client and the penetration testing team by ensuring that all testing activities remain within approved boundaries and that any potential business impact is understood before exploitation begins.

3. As a cybersecurity consultant, you were part of a team hired to conduct pen testing to evaluate the security of your client's IT infrastructure. Why is it critical to perform pen testing on the internal network of your client prior to production implementation?

Performing penetration testing on the internal network before production implementation is critical because it identifies security weaknesses before systems become operational and exposed to users or attackers. Internal testing can uncover configuration errors, vulnerable services, weak authentication mechanisms, excessive user privileges, and unpatched software that may not be detected during standard vulnerability scans. By identifying these issues early, organizations can remediate vulnerabilities before deployment, reducing the likelihood of security incidents, operational disruptions, and costly remediation after production. Internal penetration testing also verifies that security controls function as intended and provides confidence that new systems meet the organization's security requirements before they are placed into service.

4. Assuming you received an email from your boss asking you to urgently click a link in the email or asking for your sensitive data such as credit card information. What will you do as a matter of urgency needing immediate response? Describe your approach.

My first response would be to avoid clicking the link or providing any requested sensitive information. I would carefully examine the sender's email address, verify the legitimacy of the request through an alternate communication method such as a phone call or Microsoft Teams, and inspect the email for common phishing indicators, including unusual urgency, spelling or grammatical errors, suspicious links, or unexpected requests for confidential information. If I determine that the message is suspicious, I would immediately report it to the organization's cybersecurity or IT security team using the established incident reporting procedures. I would then delete or quarantine the email according to company policy. This approach helps prevent credential theft, financial fraud, and malware infections while supporting the organization's overall security awareness and incident response efforts.

Conclusion

This penetration testing exercise demonstrated the importance of a structured approach to identifying, assessing, and validating security vulnerabilities within an organization's IT environment. During the discovery phase, network hosts, services, and web applications were identified using reconnaissance tools. The vulnerability assessment phase utilized tools such as Nikto, WPScan, and OpenVAS to identify security weaknesses, outdated software, and potential attack vectors. Finally, the exploitation phase

demonstrated how attackers can leverage known vulnerabilities using the Metasploit Framework and conduct social engineering attacks using the Social Engineering Toolkit (SET) to capture user credentials within a controlled laboratory environment.

The results of this assessment emphasize that vulnerability scanning alone is not sufficient to evaluate an organization's security posture. Controlled exploitation validates whether identified vulnerabilities can be successfully leveraged by an attacker, allowing organizations to better prioritize remediation efforts based on actual risk. Equally important, the phishing simulation highlighted the critical role that user awareness and security training play in defending against social engineering attacks.

Overall, this laboratory reinforced the value of performing regular penetration testing as part of a comprehensive cybersecurity program. By combining routine vulnerability assessments, secure system configuration, timely patch management, strong access controls, and ongoing security awareness training, organizations can significantly reduce their attack surface and improve their ability to detect, prevent, and respond to evolving cyber threats.

4.4. Appendix D – Post-Exploitation Cleanup Phase

Appendix D – Post-Exploitation Cleanup

Objective

Document the actions performed following completion of the penetration testing engagement to ensure the testing environment was returned to a secure state, temporary testing artifacts were removed, and no unauthorized access mechanisms or sensitive data remained on the target systems. Post-exploitation cleanup helps maintain system integrity, reduces operational risk, and demonstrates professional penetration testing practices.

Cleanup Activities Performed

1. Termination of Penetration Testing Sessions

All Metasploit Framework (MSF) sessions, Meterpreter sessions, and Social Engineering Toolkit (SET) processes were terminated immediately after testing activities concluded. No active exploitation sessions remained connected to the target environment.

2. Removal of Temporary Exploitation Artifacts

Temporary payloads, generated exploit files, cloned phishing pages, and other testing artifacts created during the assessment were removed from the penetration testing environment. No malicious software or exploit code was intentionally left on any assessed system.

3. Credential Protection

Credentials captured during the simulated Credential Harvester exercise were used solely to validate the effectiveness of the phishing simulation within the authorized laboratory

environment. All captured test credentials were securely removed after testing and were not retained or reused.

4. Verification of System Integrity

The testing team verified that no unauthorized user accounts, scheduled tasks, persistence mechanisms, modified system configurations, or backdoor access methods remained following completion of the assessment. Systems were confirmed to be in their pre-testing operational state.

5. Documentation and Reporting

All findings, exploitation results, supporting evidence, screenshots, and remediation recommendations were documented within the Penetration Testing Report. Documentation was reviewed to ensure the results accurately reflected activities performed during each phase of the assessment and provided actionable recommendations for improving FICBANK's overall cybersecurity posture.

6. Lessons Learned

The penetration testing engagement demonstrated the importance of routine vulnerability assessments, secure system configuration, timely patch management, user security awareness training, and continuous monitoring. Although the assessment was conducted within an authorized laboratory environment, the findings illustrate how similar weaknesses could be exploited within a production environment if left unaddressed. Implementing the recommendations contained in this report will help reduce organizational risk, strengthen defensive capabilities, and improve FICBANK's overall security posture.

Reflection Questions

Question 1

Based on your pen testing experience gained in this lab, what can you do to ensure that your client organization incorporates pen testing as part of its implementation and mitigation procedures to ensure optimum internal or external security?

Answer

To ensure that FICBANK incorporates penetration testing into its overall cybersecurity strategy, penetration testing should become part of the organization's continuous risk management and system development lifecycle rather than being performed only after security incidents occur. Comprehensive penetration tests should be conducted at least annually and whenever significant infrastructure changes, new applications, or major system upgrades are implemented. In addition, routine vulnerability assessments should be scheduled throughout the year to identify newly discovered security weaknesses before they can be exploited.

FICBANK Penetration Testing Plan & Report for FICBANK Enterprise Network Version 5.0, July 27, 2026

The results of each penetration test should be integrated into the organization's vulnerability management and risk management processes. Identified findings should be prioritized according to their severity, likelihood of exploitation, and potential business impact, with remediation efforts tracked through completion. Management should regularly review penetration testing reports to ensure corrective actions are implemented and verified. Incorporating penetration testing into change management, patch management, and continuous monitoring programs will strengthen FICBANK's overall security posture while reducing the likelihood of successful cyberattacks.

Question 2

As a cybersecurity consultant, you were part of a team hired to conduct pen testing to evaluate the security of your client's IT infrastructure. Why is it critical to perform pen testing on the internal network of your client prior to production implementation?

Answer

Performing penetration testing before production implementation allows security weaknesses to be identified and remediated before systems become accessible to legitimate users or potential attackers. Internal testing validates the effectiveness of security controls, identifies configuration errors, and confirms that vulnerabilities cannot be exploited before systems support critical business operations. Addressing security issues during implementation is generally less costly and less disruptive than responding to a successful cyberattack after deployment.

Internal penetration testing also evaluates the organization's ability to detect unauthorized activity, verifies that security controls function as intended, and provides assurance that sensitive information is adequately protected. By identifying vulnerabilities before production, FICBANK reduces operational risk, minimizes the likelihood of service disruptions, protects customer information, and improves overall confidence in the security of its information systems.

Question 3

Based on the successful attacks you executed for example, exposing user credentials with the Credential Harvester what kinds of cleanup activities would be necessary?

Answer

Following a successful penetration test, all testing artifacts should be removed to restore the environment to its original operational state. This includes terminating Metasploit and Social Engineering Toolkit sessions, removing cloned phishing websites, deleting generated payloads and temporary files, and ensuring no persistence mechanisms, backdoors, or unauthorized user accounts remain on the target systems. Any credentials captured during testing should be securely deleted after validating the results and should never be retained beyond the authorized engagement.

The penetration testing team should also verify that system configurations have been restored, review logs to confirm no unintended changes remain, and document all cleanup activities within the final penetration testing report. Finally, findings and remediation recommendations should be reviewed with management to ensure vulnerabilities are addressed, corrective actions are verified, and lessons learned are incorporated into future security improvement initiatives.

Conclusion

The post-exploitation phase concluded with the successful cleanup of testing activities, verification that no unauthorized artifacts or persistence mechanisms remained within the assessment environment, and documentation of all findings identified throughout the penetration testing engagement. The assessment demonstrated that while several effective security controls were in place, multiple vulnerabilities and configuration weaknesses require remediation to reduce organizational risk and strengthen the overall security posture of the FICBANK Enterprise Network.

The recommendations presented in this report provide FICBANK with practical steps to improve system security, reduce the attack surface, strengthen user awareness, and enhance vulnerability management processes. By implementing these recommendations and incorporating regular vulnerability assessments and penetration testing into its cybersecurity program, FICBANK will be better positioned to identify emerging threats, protect critical business assets, and maintain a resilient security posture against evolving cyber risks.

5.0 Conclusion

This penetration testing engagement successfully evaluated the security posture of the FICBANK Enterprise Network through a structured assessment consisting of reconnaissance, vulnerability discovery, exploitation, and post-exploitation activities. Using industry-standard penetration testing tools and methodologies, the assessment identified several security weaknesses, including outdated software, insecure network configurations, weak cryptographic implementations, exposed services, missing web security controls, and vulnerabilities that could be exploited through social engineering attacks. Each finding demonstrated how seemingly minor weaknesses can increase organizational risk when combined within a real-world attack scenario.

Throughout the engagement, testing activities were conducted within the authorized scope and in accordance with established Rules of Engagement to ensure that business operations remained unaffected while accurately assessing the effectiveness of existing security controls. The successful exploitation of selected vulnerabilities demonstrated the importance of proactive security testing and highlighted opportunities to strengthen FICBANK's overall defensive posture before these weaknesses can be exploited by malicious actors.

The remediation recommendations provided in this report offer both immediate corrective actions and long-term security improvements designed to reduce risk and improve resilience. Priorities include implementing timely patch management, strengthening authentication and access controls, reducing the organization's attack surface, enhancing security awareness training, improving vulnerability management processes, and conducting regular penetration testing as part of an ongoing cybersecurity program.

Cybersecurity is a continuous process rather than a one-time activity. As technologies evolve and new threats emerge, organizations must continually assess, monitor, and improve their security controls to remain resilient against increasingly sophisticated attacks. By implementing the recommendations presented in this report and integrating continuous vulnerability management into its cybersecurity strategy, FICBANK will significantly strengthen its ability to protect critical business systems, safeguard

sensitive information, maintain regulatory compliance, and reduce the likelihood of future security incidents.

References

Greenbone Networks. (n.d.). *Greenbone OpenVAS*. <https://www.greenbone.net/>

Lyon, G. F. (n.d.). *Nmap: Network Mapper*. <https://nmap.org/>

National Institute of Standards and Technology. (2008). *Technical guide to information security testing and assessment* (Special Publication 800-115). U.S. Department of Commerce. <https://csrc.nist.gov/pubs/sp/800/115/final>

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (Special Publication 800-53, Revision 5). U.S. Department of Commerce. <https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>

Offensive Security. (n.d.). *Metasploit Framework*. <https://www.metasploit.com/>

Open Web Application Security Project. (n.d.). *OWASP Web Security Testing Guide*. <https://owasp.org/www-project-web-security-testing-guide/>

OWASP Foundation. (n.d.). *DirBuster Project*. <https://owasp.org/www-project-dirbuster/>

Sullo, C. (n.d.). *Nikto Web Server Scanner*. <https://github.com/sullo/nikto>

TrustedSec. (n.d.). *Social-Engineer Toolkit (SET)*. <https://github.com/trustedsec/social-engineer-toolkit>

WPScan Team. (n.d.). *WPScan WordPress Security Scanner*. <https://wpscan.com/>